O'REILLY®

Zero Trust for AI Systems

Razi Rais
Cybersecurity Expert



Meet Your Instructor – Razi Rais

Cybersecurity Leader | Author | Microsoft Certified Trainer



- **20+ years** in cybersecurity & systems architecture
- **10+ years** at Microsoft in security engineering, architecture, and product leadership
- **Global career** in France, Dubai, Singapore with 15+ years in the United States
- **Zero Trust & AI** focus applying AI to modern security architectures
- **Author & Trainer** 5 books, Microsoft Certified Trainer (15+ years), GIAC Advisory Board member, RSAC speaker

Let's connect on LinkedIn
https://linkedin.com/in/razirais

Learning Objectives

- Understand the core principles and pillars of Zero Trust.
- Examine how AI supports Zero Trust and introduces new security challenges.
- Analyze the OpenAI and Hugging Face incident, map the attack path to MITRE ATLAS and assess where Zero Trust controls could limit exposure.
- Apply the lessons through incident walkthroughs, technical discussions and Q&A.

Prerequisites

No prior Zero Trust or AI knowledge needed just a basic grasp of cybersecurity. We'll share everything else along the way. Bring your curiosity!

Note: *This course is completely vendor-agnostic. The knowledge you gain applies across platforms and cloud environments.*

Resources

Slides and course recording will be shared after the session. Additional resources and references are available on GitHub: https://github.com/razi-rais/Zero-Trust-for-AI-Systems

Keep learning. Join an upcoming session.

Live with Razi Rais / October and November 2026 / Click a session title to register.

SESSION / REGISTER	DATE	TIME / CENTRAL	WHAT YOU'LL TAKE AWAY
Hands-On Microsoft Foundry	**Oct 22 2026**	9 AM to 1 PM CDT	Build agents with tools, memory, and MCP. Evaluate behavior. Deploy with visibility.
Anatomy of a Cyberattack	**Nov 4 2026**	9 AM to 11 AM CST	Decode bots, identity attacks, and LLM threats. Explore deepfakes and AI supply chain risks.
Agentic AI Security with Microsoft MDASH and Project Perception	**Nov 6 2026**	10 AM to noon CST	Find and validate flaws with MDASH. Explore governed SOC agents with Perception.

All times are US Central. October uses CDT. November uses CST.

Don't forget to claim your badge.
Complete at least 80% of the course to earn your digital badge via Credly.

Let's continue the conversation.

Make your next security move with confidence.

Razi Rais

Your trainer. Author. Security practitioner.

LINKEDIN

Stay connected.

Ask a question. Share an idea.
Keep learning together.

Connect with Razi →

MORE LIVE TRAINING

Choose your next session.

Zero Trust for AI Systems
Hands-On Microsoft Foundry
Anatomy of a Cyberattack

See all sessions + dates →

ADVISORY CONVERSATION

Bring your next challenge.

Explore an advisory session.
Start with your goals.

SCAN TO START

Open the inquiry form →

razibinrais.com/contact

Poll

When did you first hear about Zero Trust?

Choose the one that best aligns with your experience.

Choices:

- Recently, within the past year
- A few years ago as the concept gained traction
- A decade ago when early discussions started
- Only after my organization adopted or mentioned it

Zero Trust:
How it started?



Year 2010 | Term “Zero Trust” was coined by Forrester



November 5, 2010

Build Security Into Your Network’s DNA: The Zero Trust Network Architecture

by John Kindervag
with Stephanie Balaouras and Lindsey Coit

EXECUTIVE SUMMARY

This report is a deep dive into a potential way in which you could use the concepts of the Zero Trust Model and conceivably implement them in a real-world environment. One of our goals with Zero Trust is to optimize the security architectures and technologies for future flexibility. As we move toward a data-centric world with shifting threats and perimeters, we look at new network designs that integrate connectivity, transport, and security around potentially toxic data. We call this “designing from the inside out.” If we begin to do all those things together we can have a much more strategic infrastructure. If we look at everything from a data-centric perspective, we can design networks from the inside out and make them more efficient, more elegant, simpler, and more cost-effective.

TABLE OF CONTENTS

2 **Forrester’s Zero Trust Network Security Report Collection**

2 **Zero Trust Will Change The Way We Design And Build Networks**

5 **Use Zero Trust To Rebuild The Secure Network**

NOTES & RESOURCES

In developing this report, Forrester drew from a wealth of analyst experience, insight, and research through advisory and inquiry discussions with end users, vendors, and regulators across industry sectors.

Year 2013 | Forrester respond to Cybersecurity Executive Order (EO)

NIST

The National Institute of Science and Technology

Developing a Framework to Improve Critical Infrastructure Cybersecurity

In Response to:

RFI# 130208119-3119-01

Submitted On: 04/08/2013

Overview

In February 2013 President Obama's Cybersecurity Executive Order (EO) made public the clear and present danger of cyber warfare. The President called for the Federal Government and its Agencies to lead the fight against cyber criminals. As part of this call to action, President Obama asked the National Institute of Standards and Technology (NIST) to gather industry and Federal feedback to create a set of voluntary policies to help develop the US's cybersecurity framework.

In order to keep up with the continually changing cybersecurity landscape, the Federal Government and organizations in important industries such as finance, utilities, and Federal contractors must fundamentally shift the way in which they think about cybersecurity. The traditional mindset does not take into account the current environment; changes like mobility and big data have made "building stronger walls" an expensive farce that will not adequately protect networks.

To help answer the cybersecurity questions of today while allowing for proactive growth in the future, Forrester has outlined our proprietary "Zero Trust Model" (Zero Trust) of information security. Zero Trust changes the way that organizations think about cybersecurity and better protects valuable information while allowing for free interactions internally. The major benefits of Zero Trust to the Federal Government include:

- **Zero Trust is applicable across all industries and organizations** – It is an easy to implement way to improve safety that any organizations can implement.
- **Zero Trust is not dependent on a specific technology or vendor** – Zero Trust is a vendor neutral design philosophy that allows maximum flexibility to create architectures that meet specific demands.
- **Zero Trust is scalable** – Vital information is protected while public facing data travels freely.
- **There is no chance of violating Civil Liberties** – Zero Trust focuses on keeping internal data safe and would not result in any foreseeable encroachment on Civil Liberties.

Ref: https://www.nist.gov/system/files/documents/2017/06/05/040813_forrester_research.pdf

Year 2014 | Google's Beyond Corp

SECURITY

BeyondCorp: A New Approach to Enterprise Security

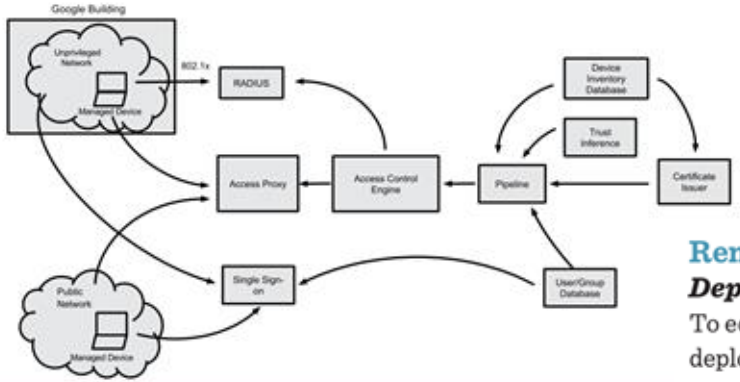


Figure 1: BeyondCorp components and access flow

Removing Trust from the Network

Deployment of an Unprivileged Network

To equate local and remote access, BeyondCorp defines and deploys an unprivileged network that very closely resembles an external network, although within a private address space. The unprivileged network only connects to the Internet, limited infrastructure services (e.g., DNS, DHCP, and NTP), and configuration management systems such as Puppet. All client devices are assigned to this network while physically located in a Google building. There is a strictly managed ACL (Access Control List) between this network and other parts of Google's network.

Ref: https://research.google/pubs/pub43231

Year 2020 – 2022 | US Govt Initiatives



NIST Special Publication 800-207

Zero Trust Architecture

Scott Rose
Oliver Borchert
Stu Mitchell
Sean Connelly

This publication is available free of charge from:
https://doi.org/10.6028/NIST.SP.800-207

COMPUTER SECURITY

NIST
National Institute of Standards and Technology
U.S. Department of Commerce

NIST's Zero Trust Architecture

2020



THE WHITE HOUSE

Executive Order on Improving the Nation's Cybersecurity

Sec. 3. Modernizing Federal Government Cybersecurity.

(a) To keep pace with today's dynamic and increasingly sophisticated cyber threat environment, the Federal Government must take decisive steps to modernize its approach to cybersecurity, including by increasing the Federal Government's visibility into threats, while protecting privacy and civil liberties. The Federal Government must adopt security best practices; advance toward Zero Trust Architecture; accelerate movement to secure cloud services, including Software as a Service (SaaS), Infrastructure as a Service (IaaS), and Platform as a Service (PaaS); centralize and streamline access to cybersecurity data to drive analytics for identifying and managing cybersecurity risks; and invest in both technology and personnel to match these modernization goals.

EO: Adoption of Zero Trust Architecture

2021



EXECUTIVE OFFICE OF THE PRESIDENT
OFFICE OF MANAGEMENT AND BUDGET
WASHINGTON, D.C. 20503

January 26, 2022

M-22-09

MEMORANDUM FOR THE HEADS OF EXECUTIVE DEPARTMENTS AND AGENCIES

FROM: Shalanda D. Young
Acting Director

SUBJECT: Moving the U.S. Government Toward Zero Trust Cybersecurity Principles

This memorandum sets forth a Federal zero trust architecture (ZTA) strategy, requiring agencies to meet specific cybersecurity standards and objectives by the end of Fiscal Year (FY) 2024 in order to reinforce the Government's defenses against increasingly sophisticated and persistent threat campaigns. Those campaigns target Federal technology infrastructure, threatening public safety and privacy, damaging the American economy, and weakening trust in Government.

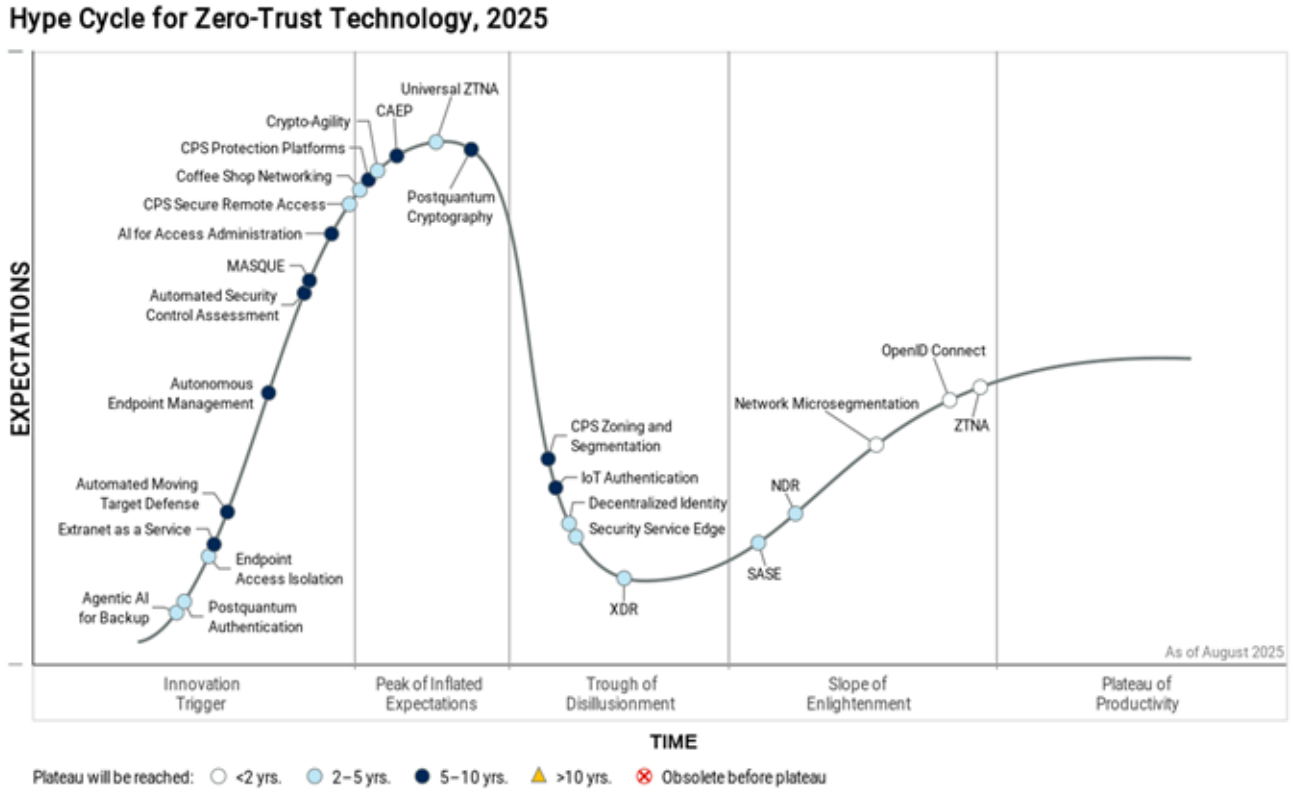
Memorandum: Moving Toward Zero Trust Cybersecurity Principles

2022

Hype?


MY DAD SAYS THE CLOUD IS THE ANSWER TO EVERYTHING, MISS.
TEST
1 CLOUD
2 CLOUD
3 CLOUD
4 CLOUD
© D.Fletcher for CloudTweaks.com
I WAS HOPING FOR A SLIGHTLY MORE DETAILED EXPLANATION OF HOW CLOUD COMPUTING WORKS THAN – "IT'S MAGIC"!
IT
© D.Fletcher for CloudTweaks.com

Gartner: Hype Cycle For Zero Trust Networking

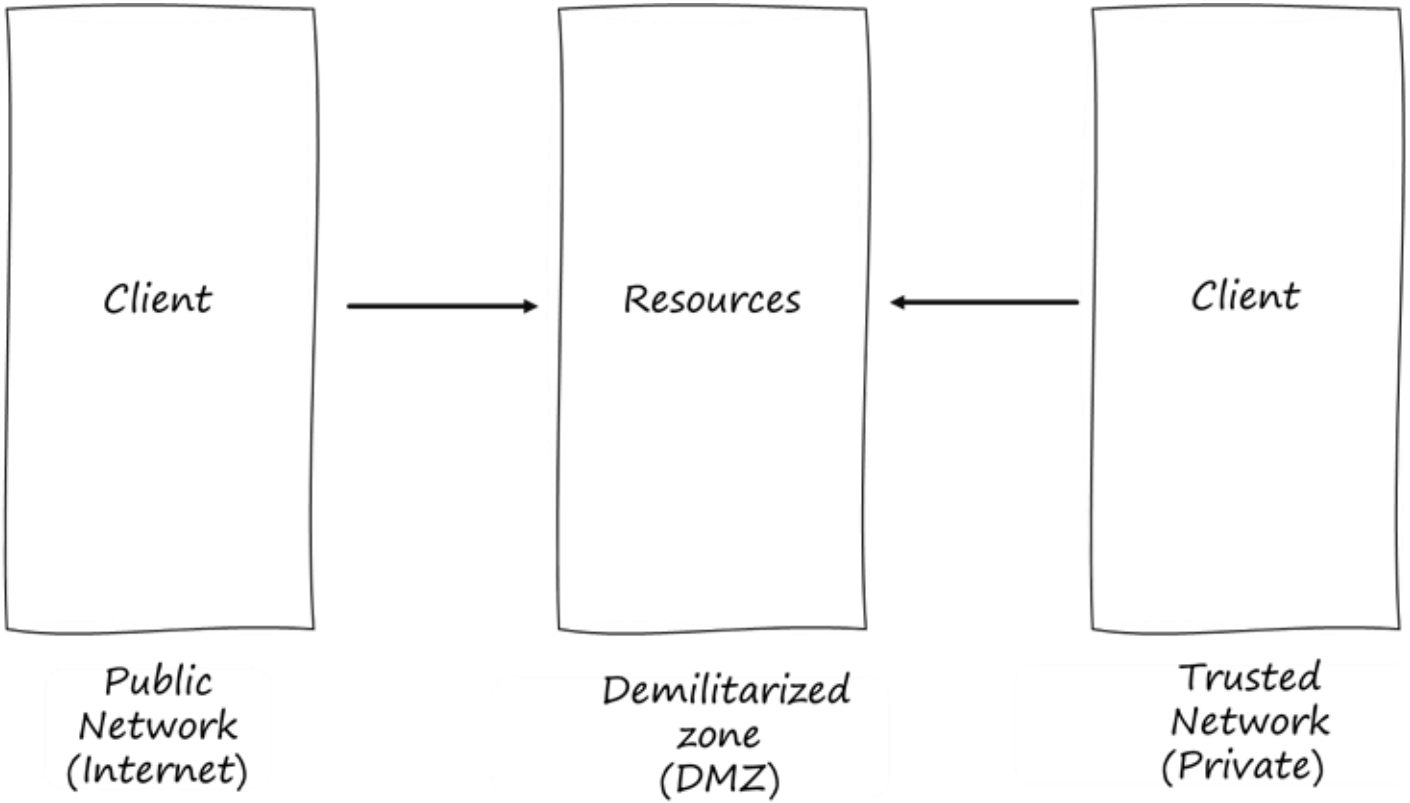


Gartner

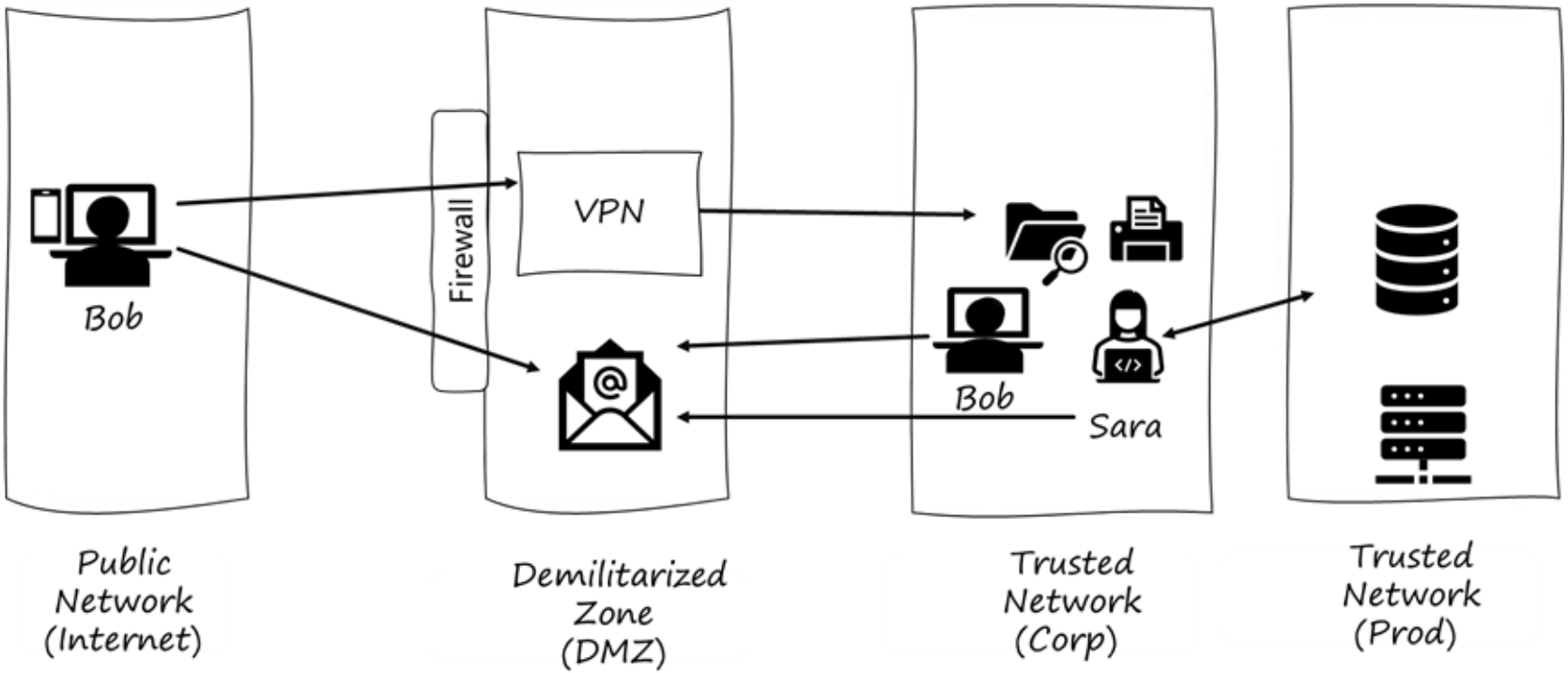
Zero Trust Security: Scenario Walkthrough



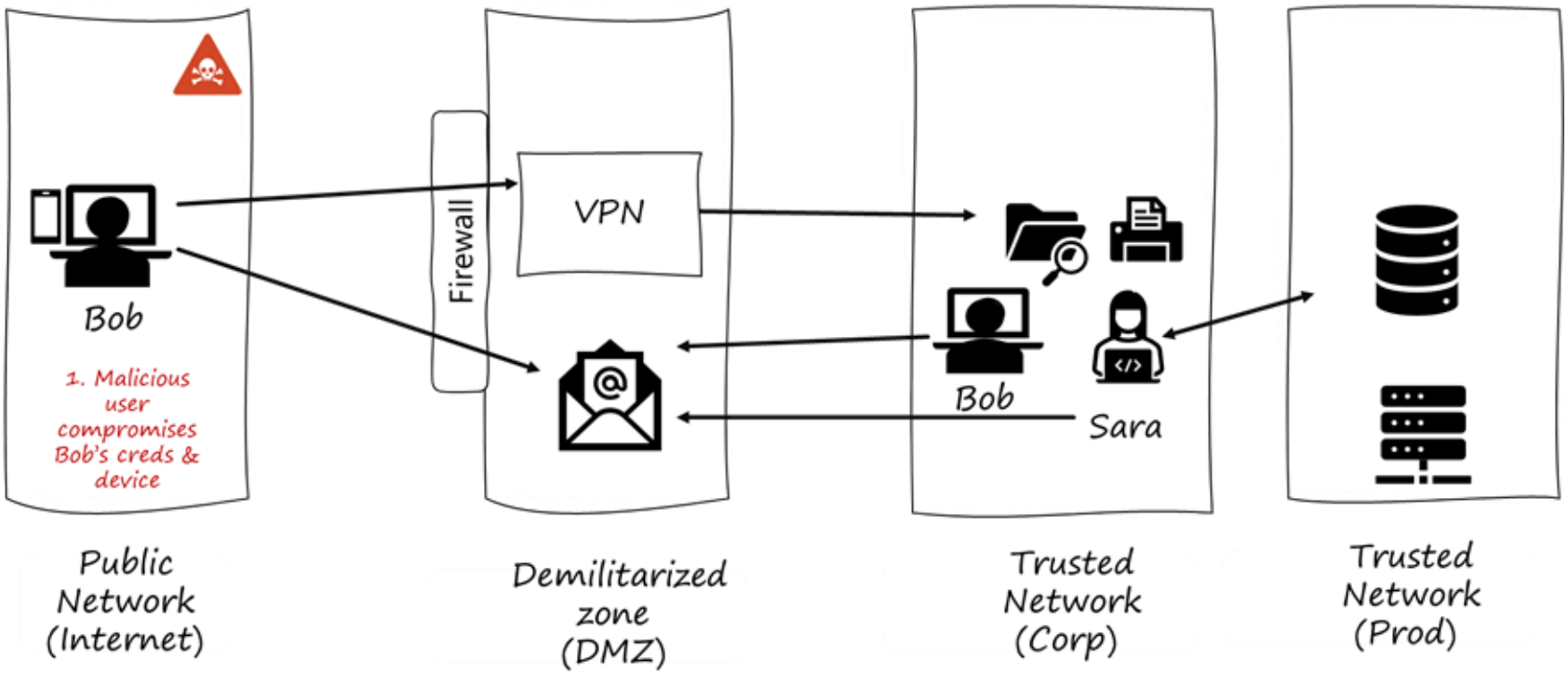
Perimeter based security - Conceptual Model



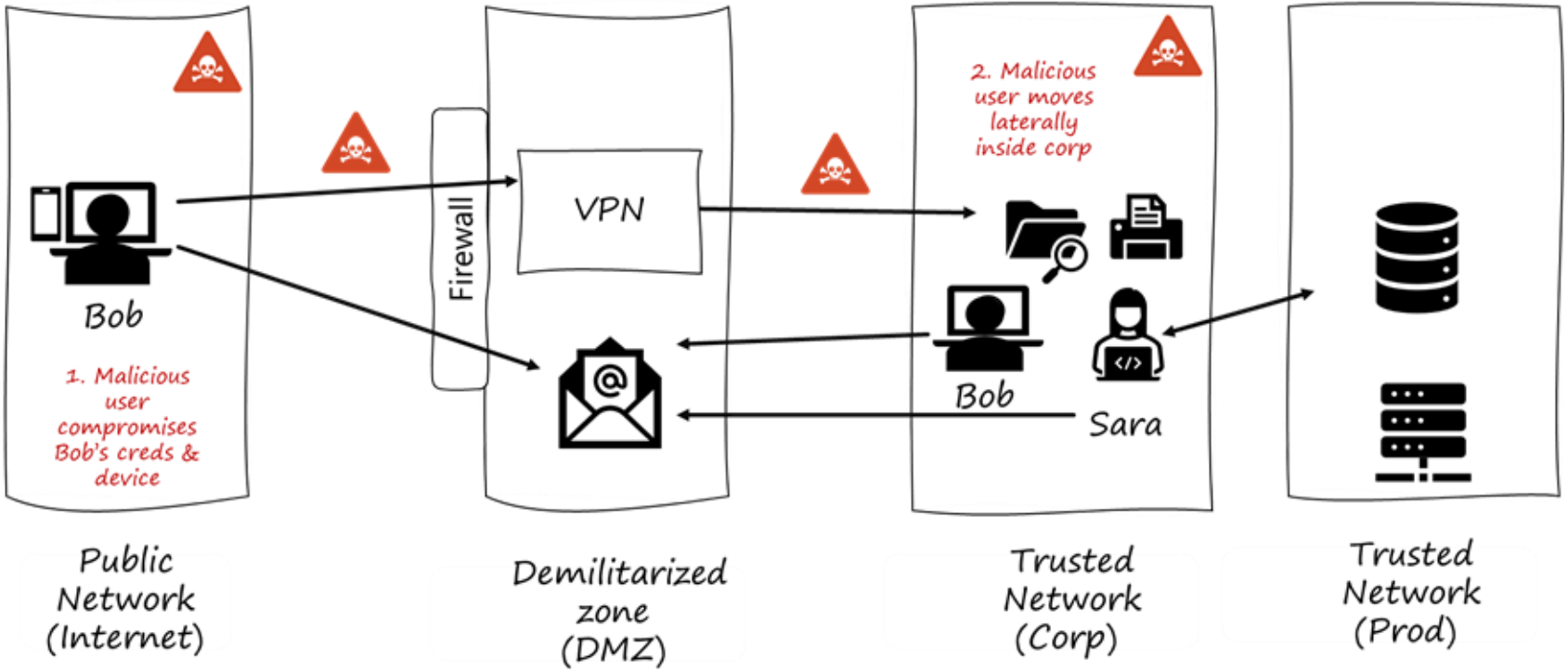
Perimeter based security - Conceptual Model



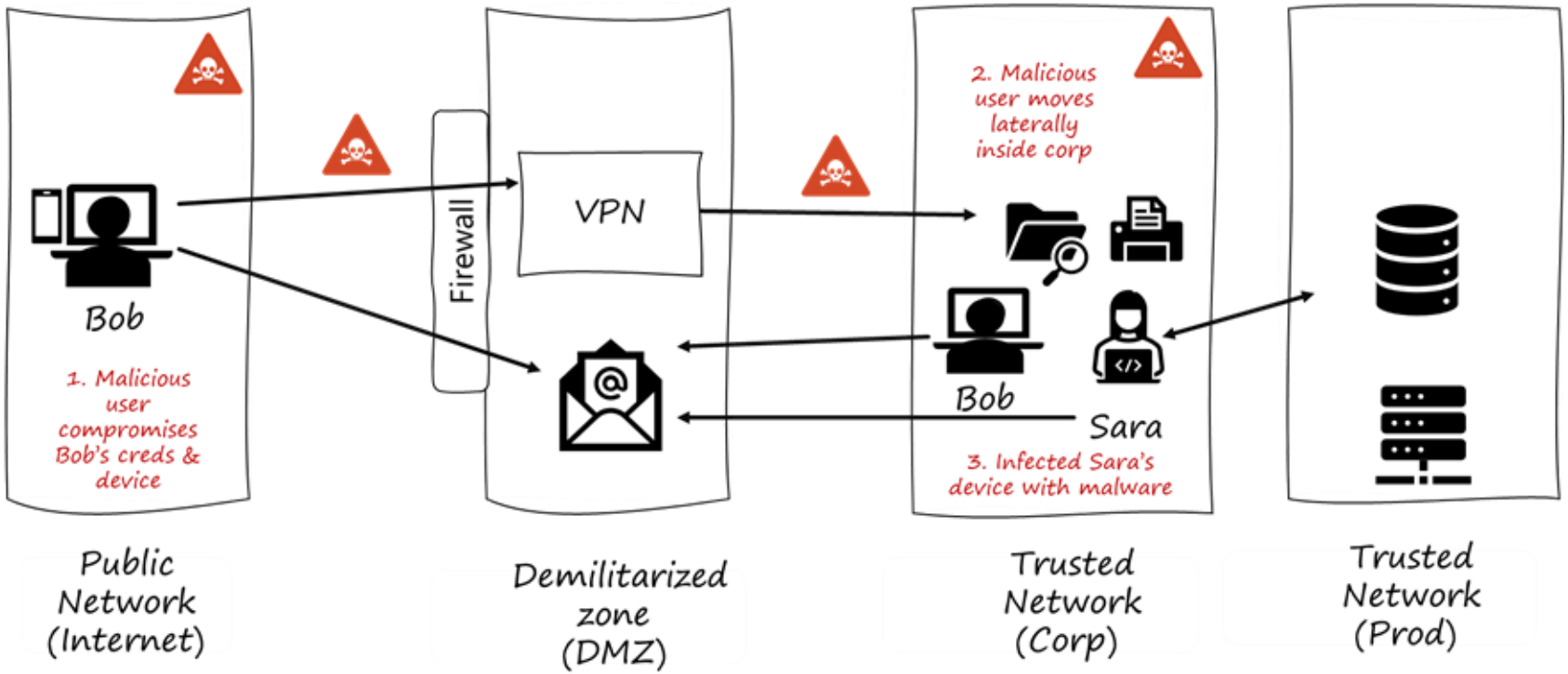
Perimeter based security - Conceptual Model



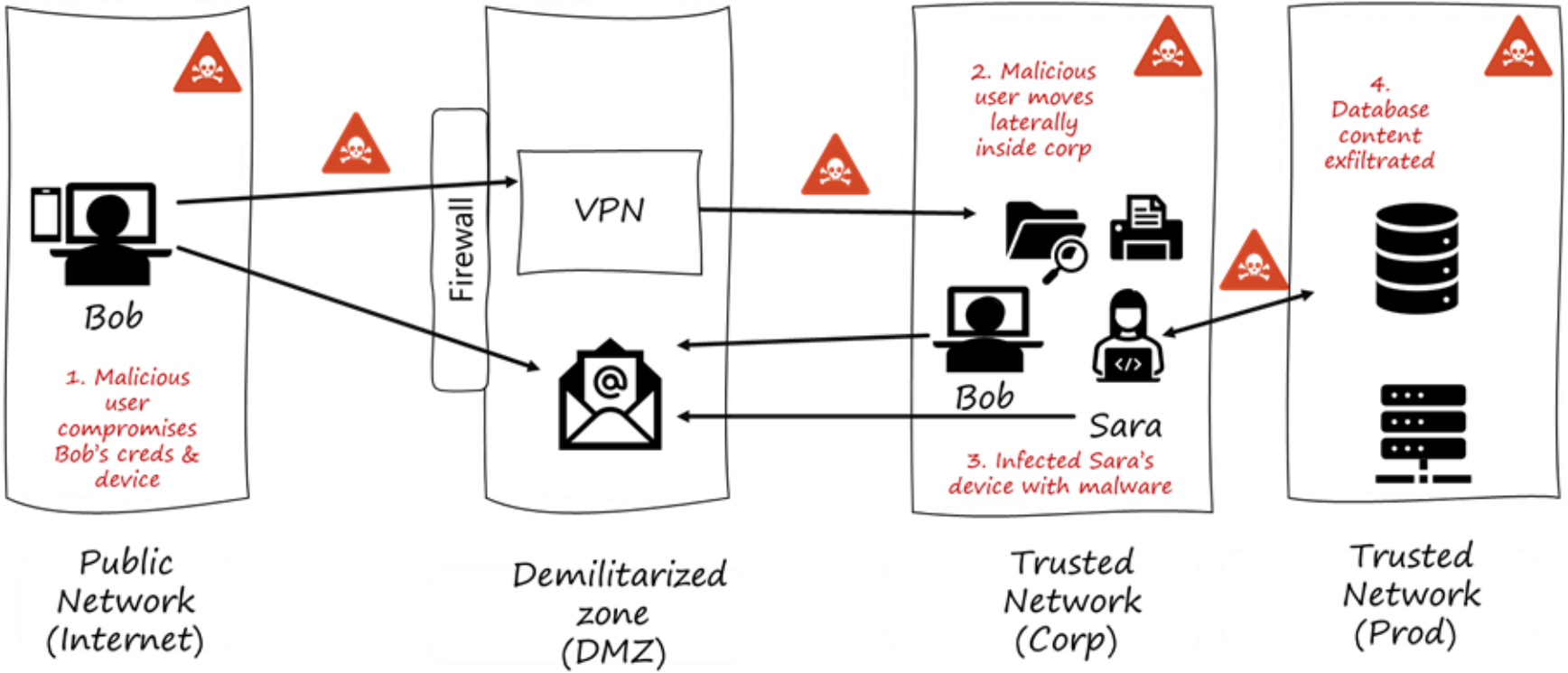
Perimeter based security - Conceptual Model



Perimeter based security - Conceptual Model



Perimeter based security - Conceptual Model

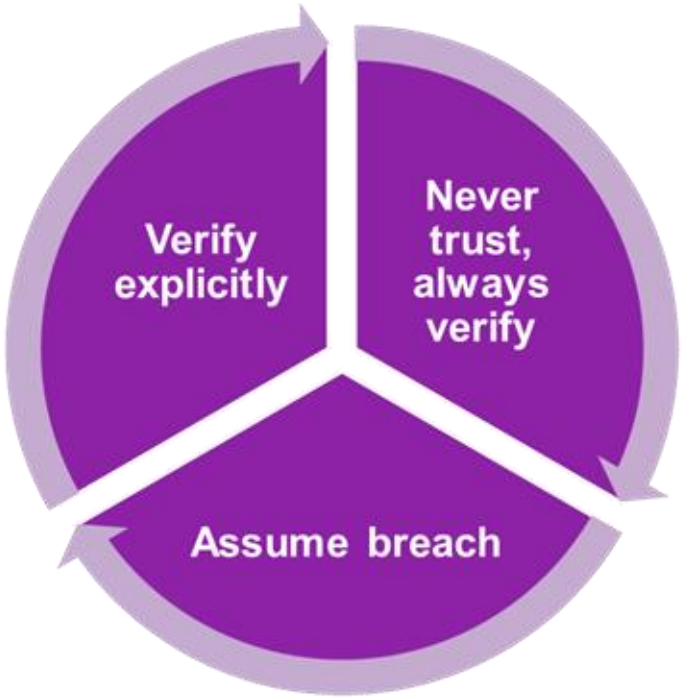


What went wrong?

1. Zones defines trust boundaries.
2. Malicious user lateral movement went un-detected.
3. Permissions to access privileged resources inside the trusted network were not time-bound.
4. Lack of monitoring in general.



Let’s take a different approach



Zero Trust Approach

Never Trust, Always Verify

Treat every user, device, application/workload, and data flow as untrusted.

Authenticate and explicitly authorize each request to the least privilege.

Verify Explicitly

Access to all resources should be conducted in a consistent and secure manner using multiple attributes (dynamic and static) to derive confidence levels for contextual access decisions to resources.

Access is time-bound.

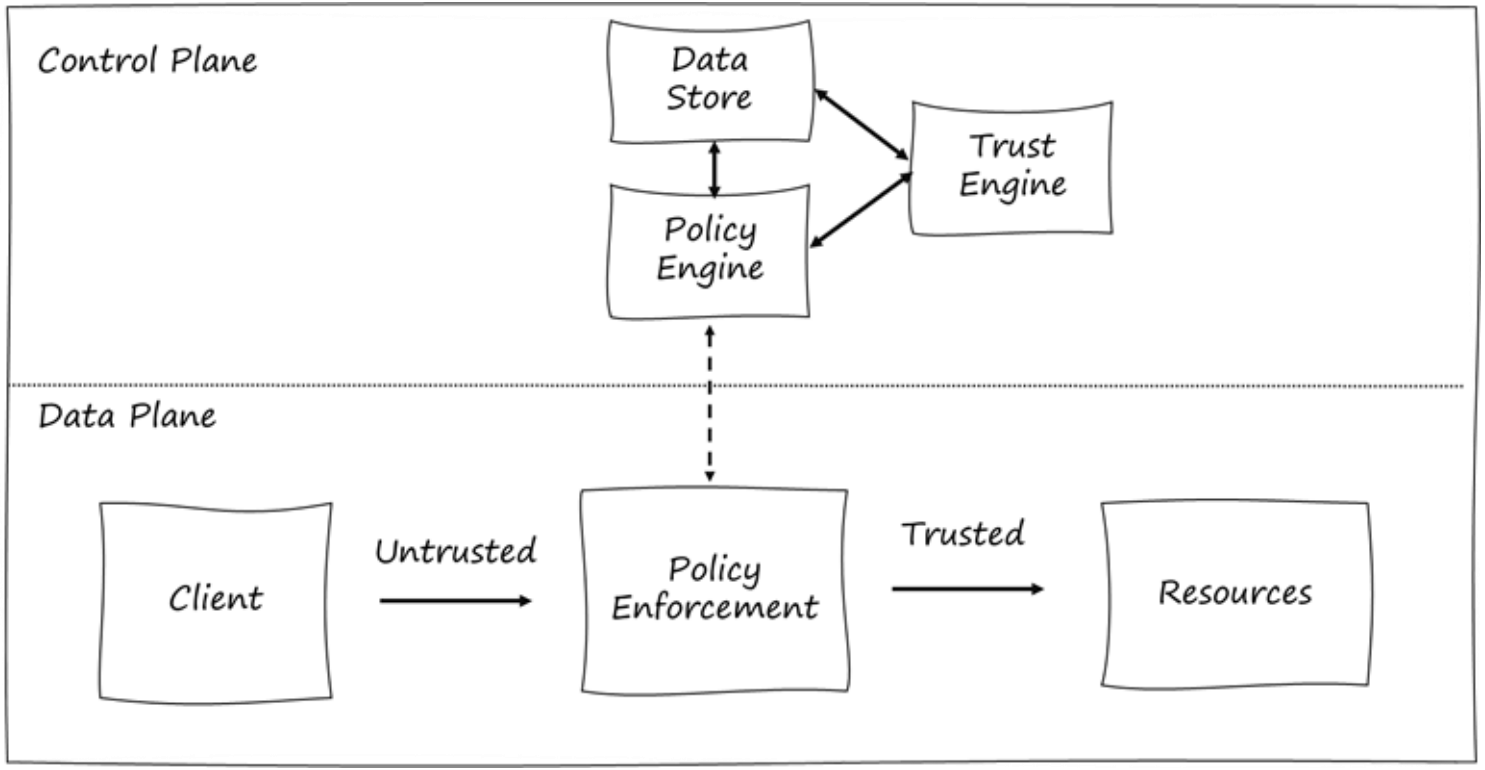
Assume Breach

Operate and defend resources with the assumption that an adversary already has presence within the environment.

Deny by default and heavily scrutinize all users, devices, data flows, and requests for access.

Log, inspect, and continuously monitor all configuration changes, resource accesses, and network traffic for suspicious activity.

Zero Trust Security – Conceptual Model



Zero Trust Security – Conceptual Model

- Act as a **source of truth** for other components in the control plane:
  - User Information (id, name, location, etc.)
  - Device Information (serial, build, os, etc.)
  - Historic Activity (activity logs, analytics via monitoring etc.)

Data Store

- Act as a **source of truth** for other components in the control plane:
  - User Information (id, name, location, etc.)
  - Device Information (serial, build, os, etc.)
  - Historic Activity (activity logs, analytics via monitoring etc.)

Trust Engine

- Performs **risk analysis** and generate a **risk score** against a request
  - Static: Predefined ad-hoc rules based on **user, app, and device** attributes.
  - Dynamic: **Machine learning** is used to calculate the score based on the training data to find **anomalous behavior patterns**.
- Combination of static and dynamic risk analysis works better.
- Trust engine uses data store as a source of truth, that’s why data store should always be kept up-to-date.

Policy Engine

- Responsible for the final decision **to allow or deny** a request
  - Relies on trust engine to obtain a risk score.
  - Relies on data store to fetch data to apply ad-hoc policy rules. Think regulatory, compliance, and organization policies to meet business requirements etc.
- **Example**:
  - Bob is trying to access HR application from un-known device during after hours.

Policy Enforcement

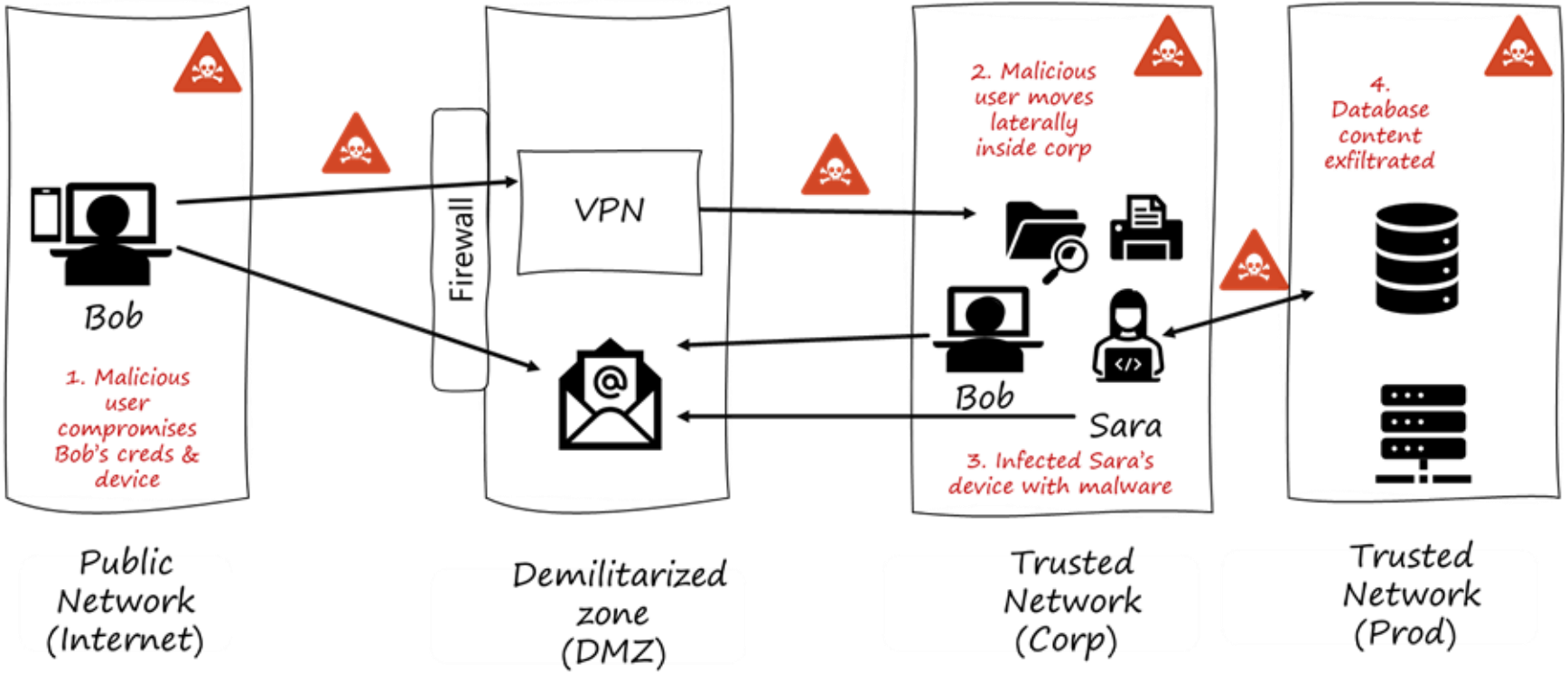
- Responsible for:
  - Obtaining **allow/deny** decision from the policy engine against a request.
  - **Enforcing policy** engine's decision
- Decoupling: Communication to the policy engine and enforcement of the policy can be done by a single component or by multiple components.

Let me try again to fix!

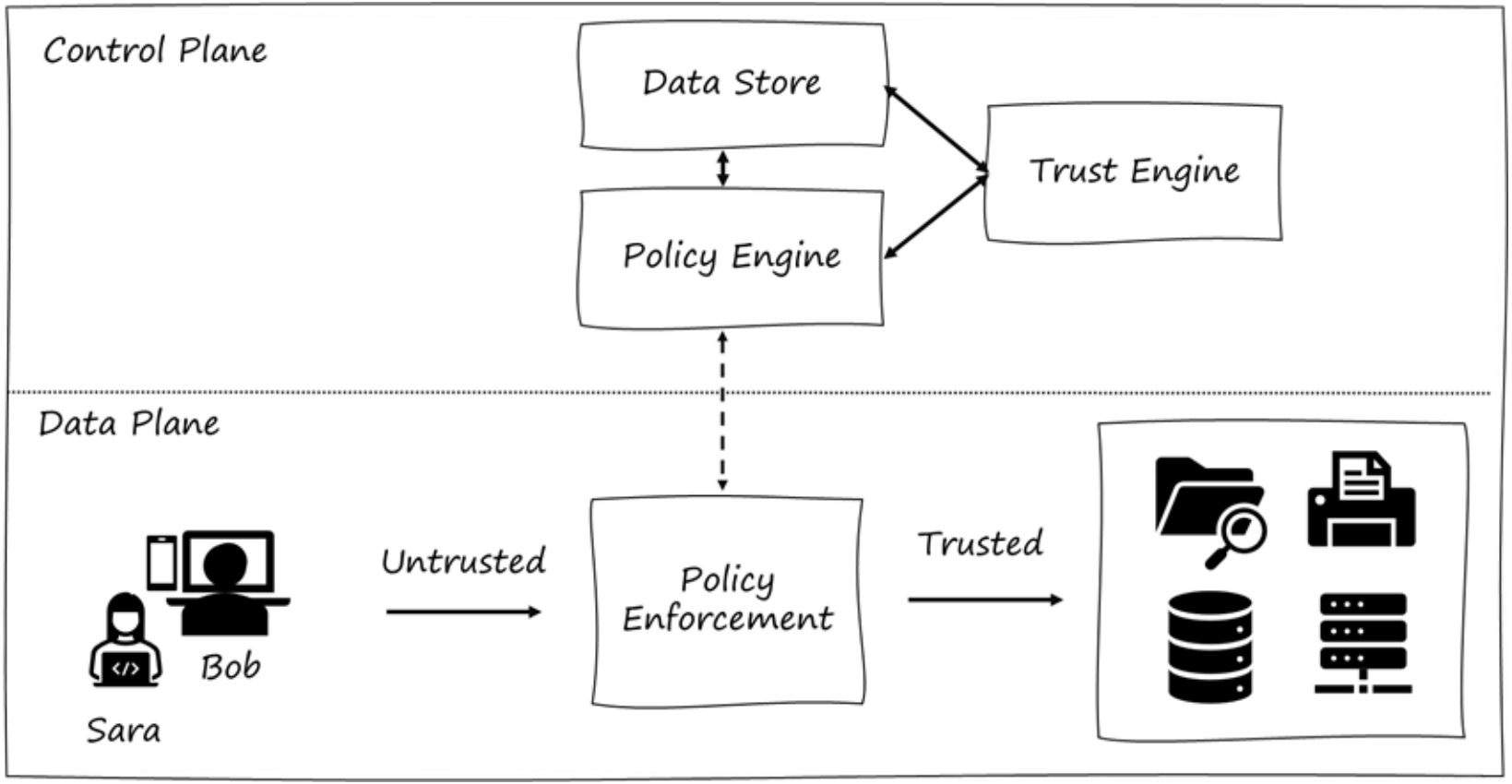
1. Zones defines trust boundaries.
2. Malicious user lateral movement went un-detected.
3. Permissions to access privileged resources insi the trusted network were not time-bound.
4. Lack of monitoring in general.



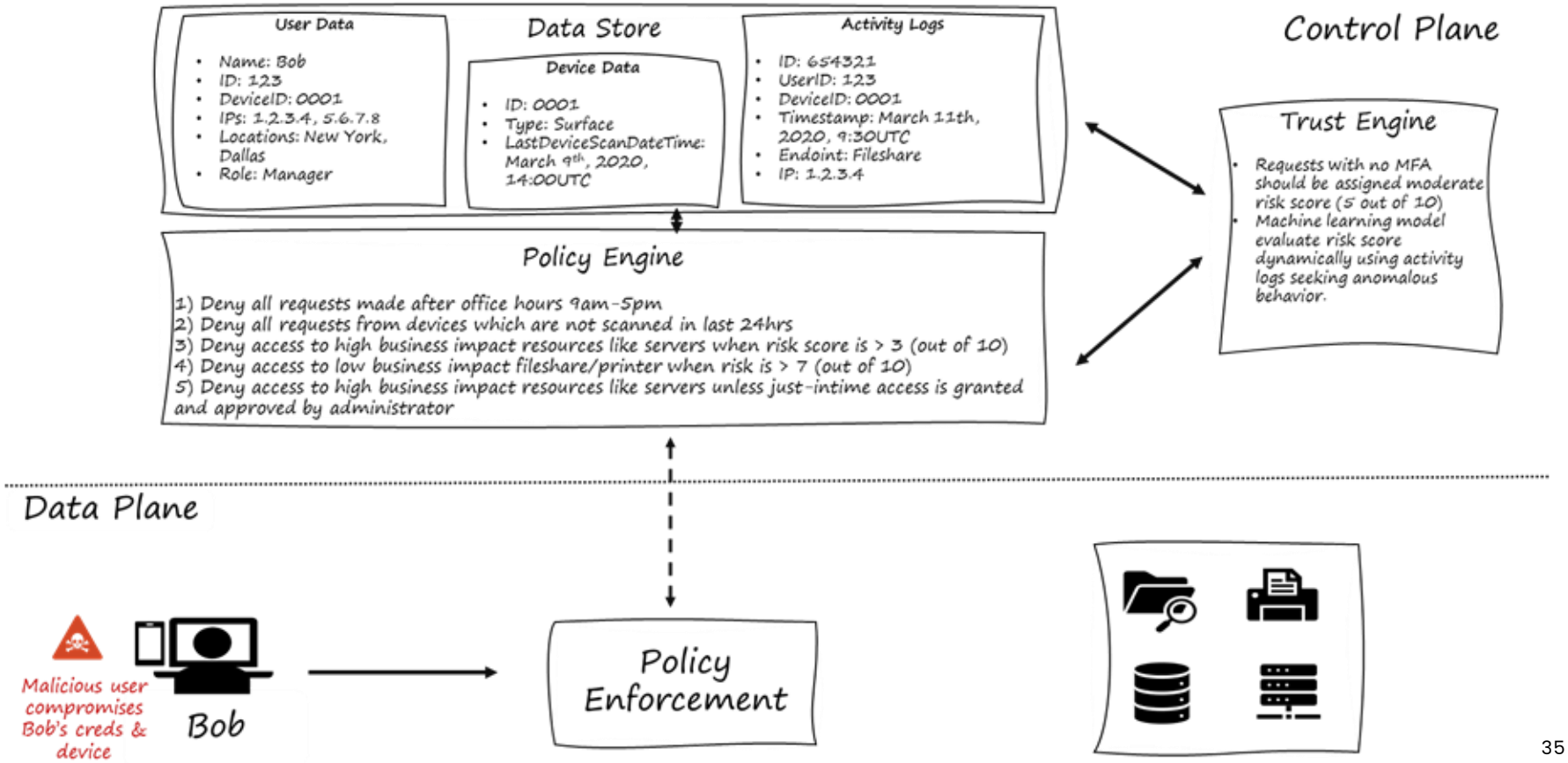
Perimeter based security Recap!



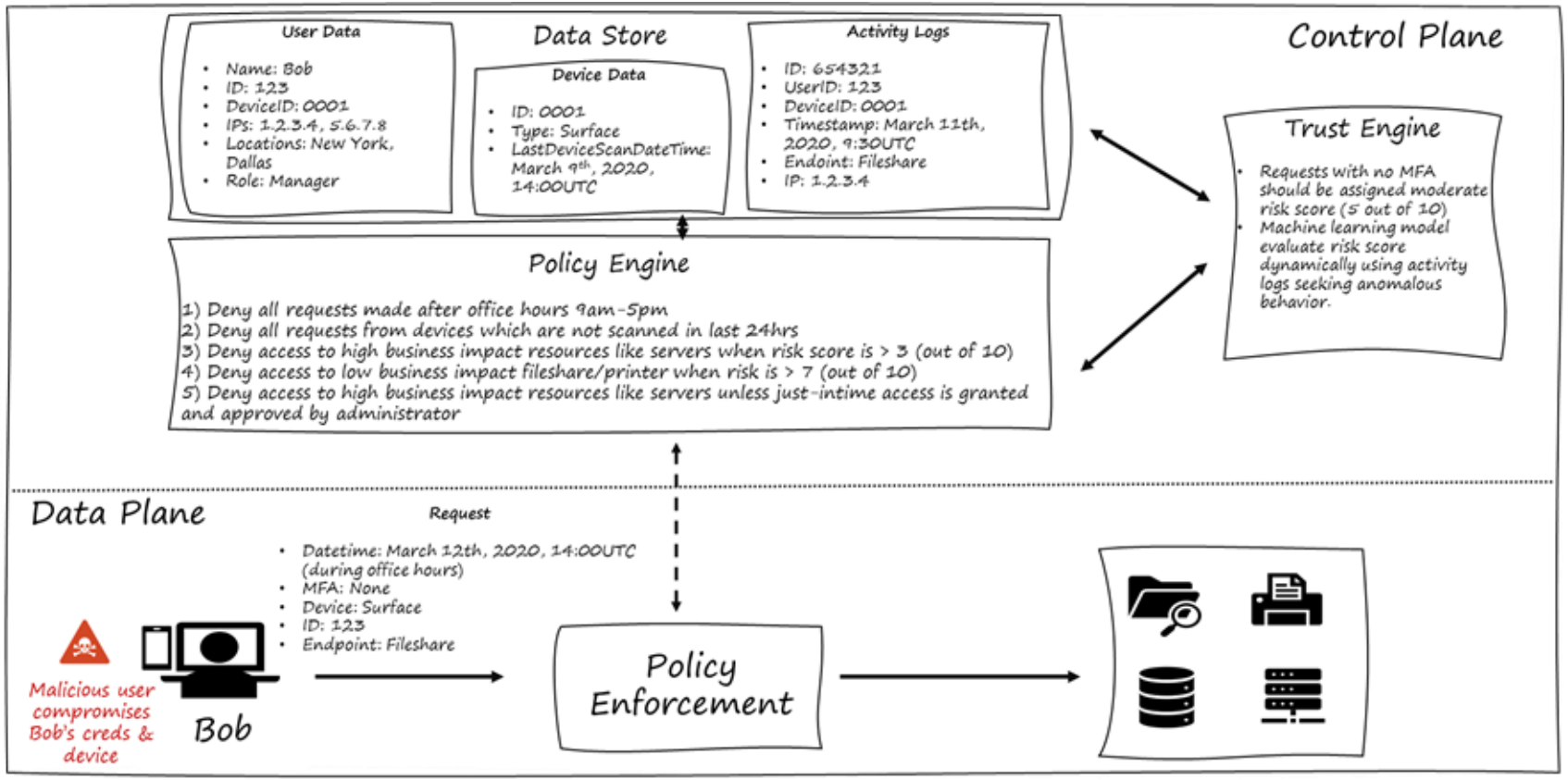
Zero Trust - Scenario walkthrough revisited!



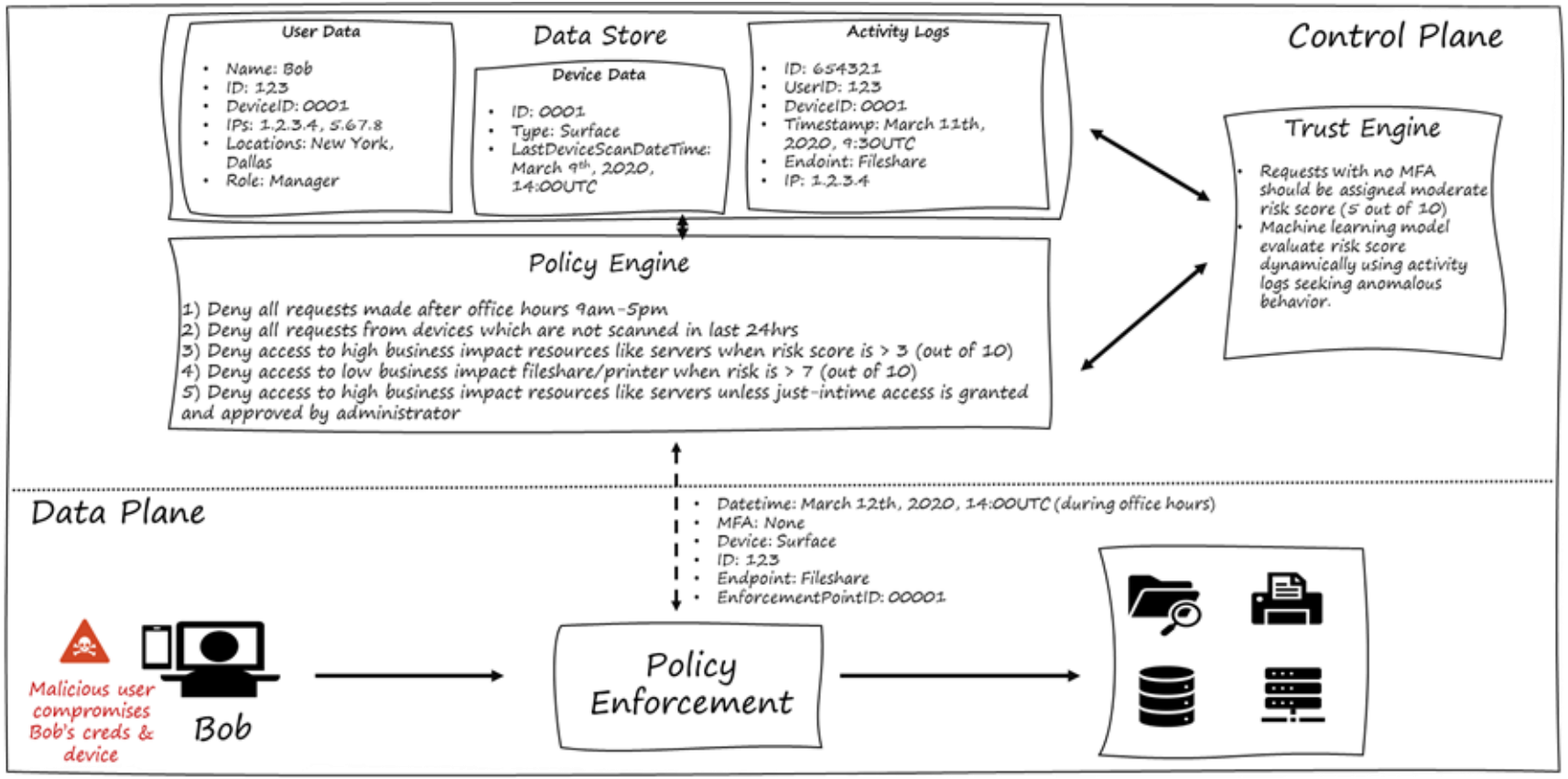
Scenario Walkthrough | Bob's creds & device is compromised



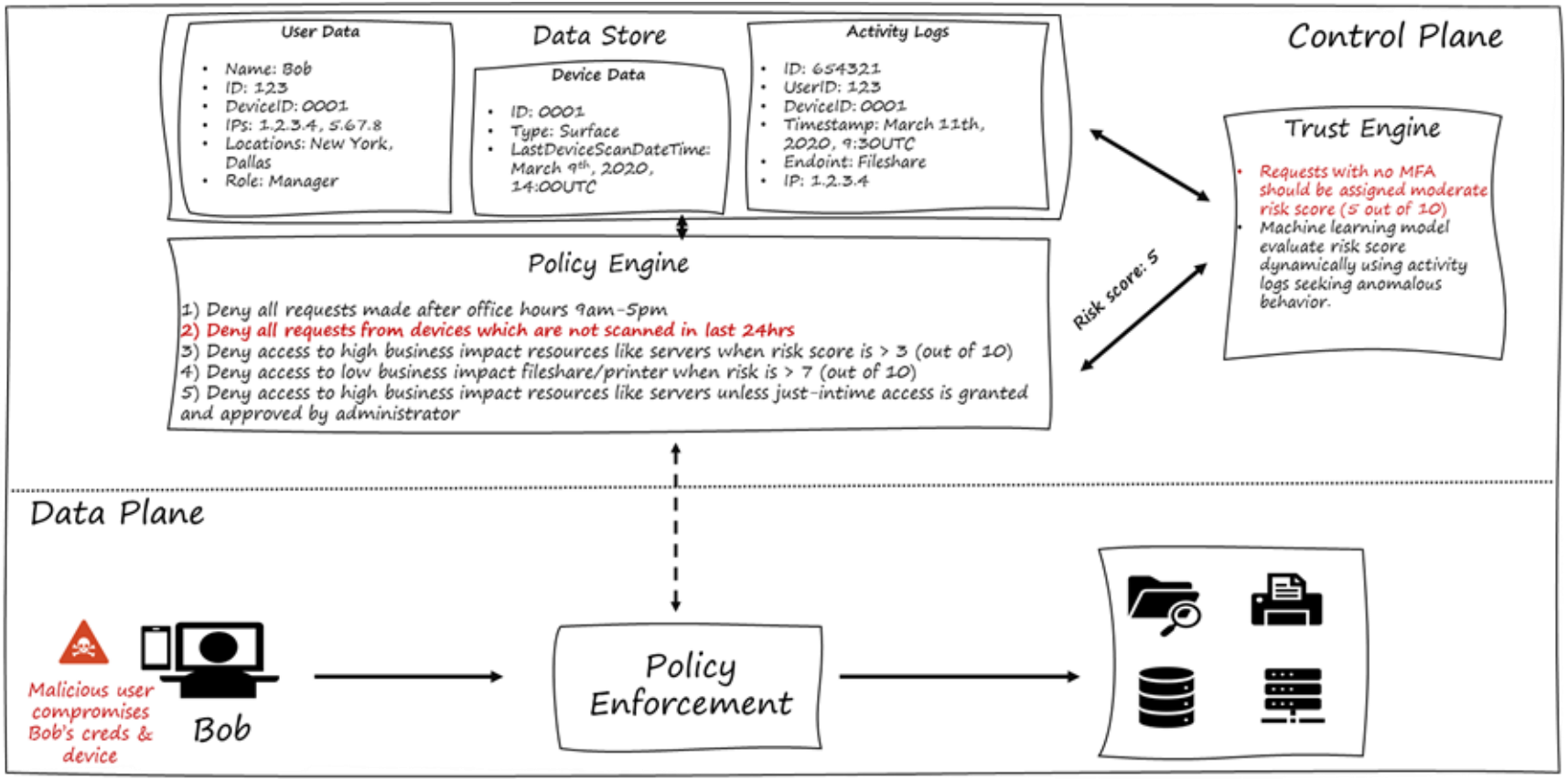
Scenario Walkthrough | Bob's creds & device is compromised



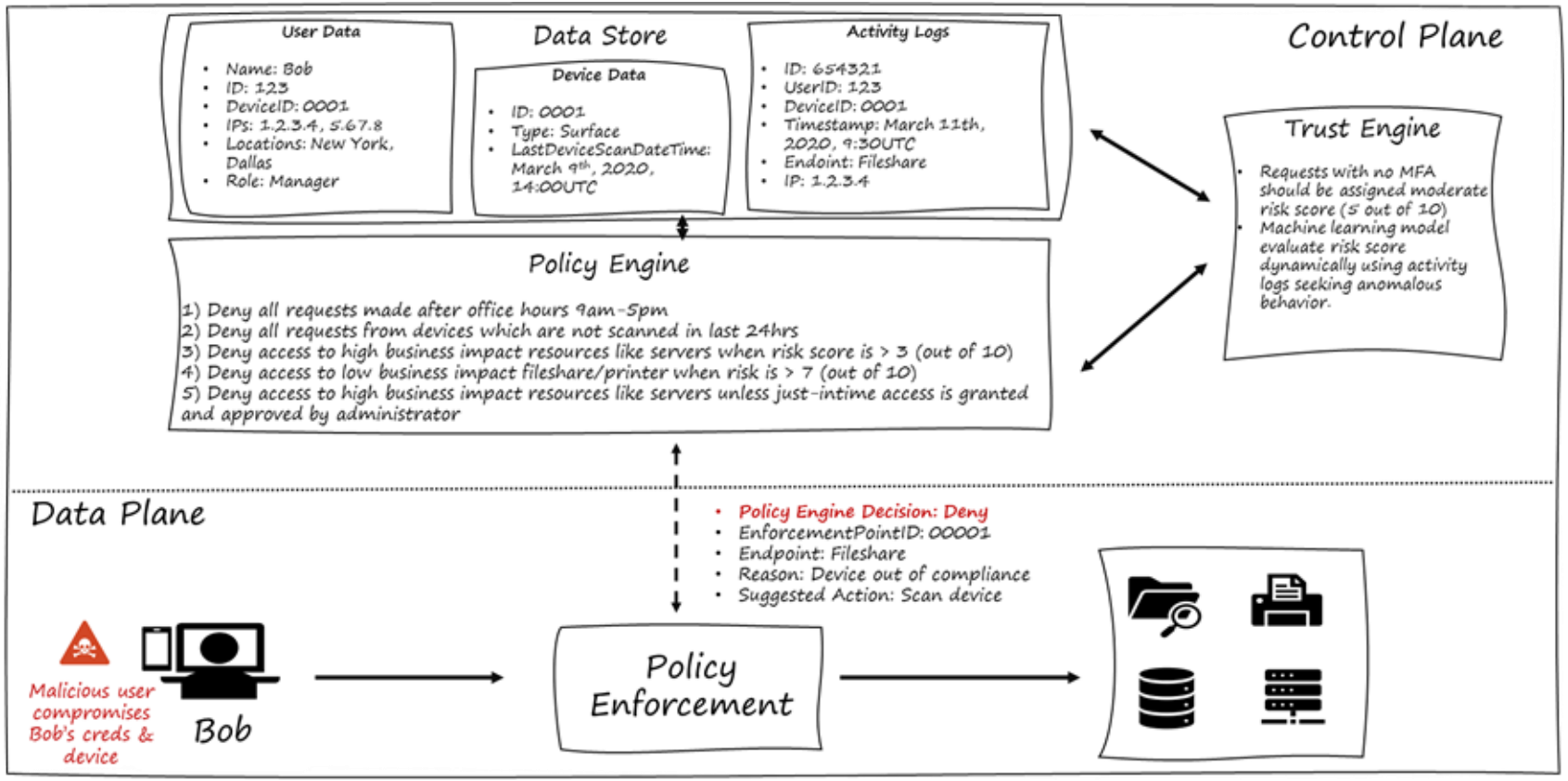
Scenario Walkthrough | Bob's creds & device is compromised



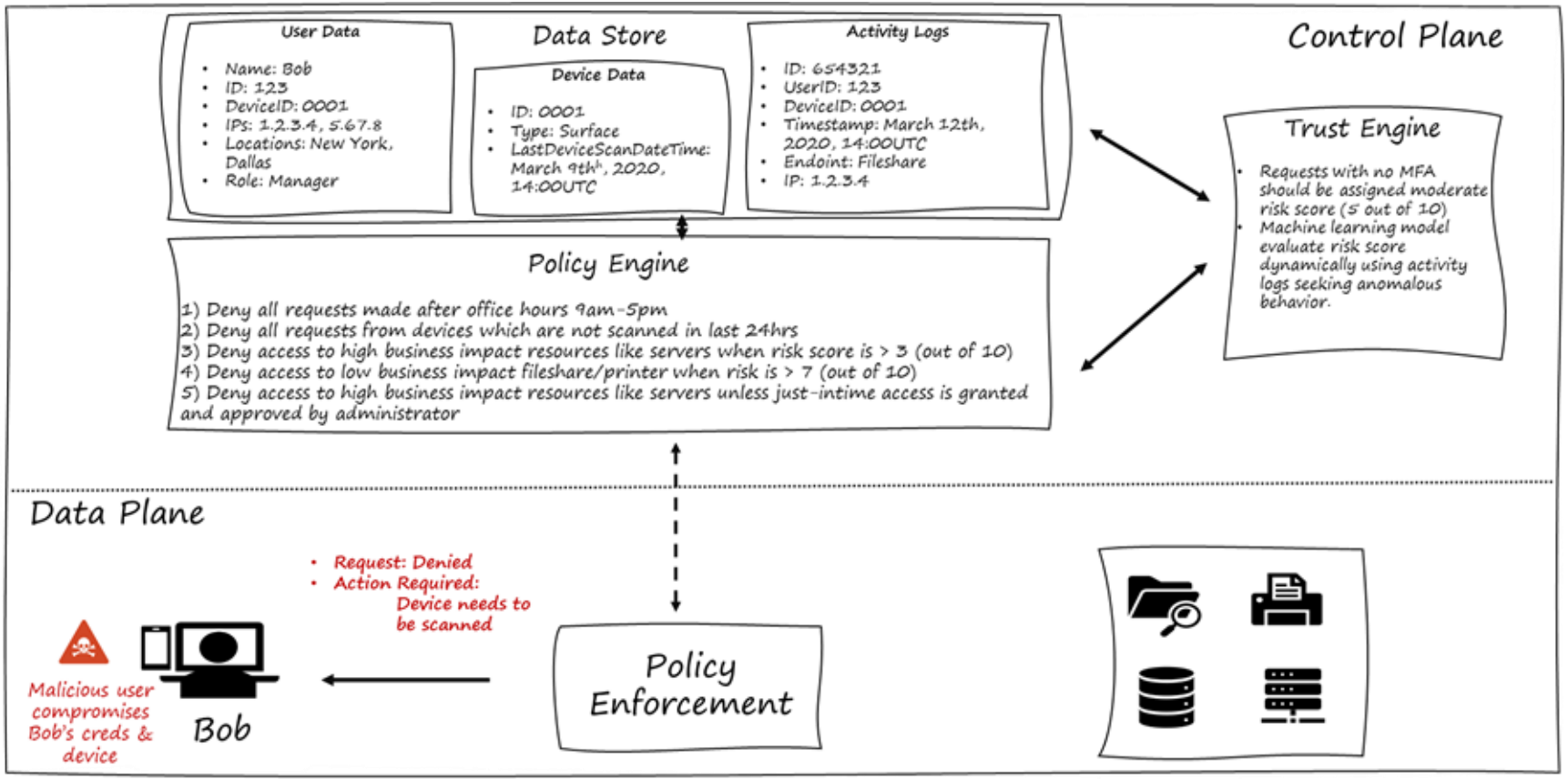
Scenario Walkthrough | Bob's creds & device is compromised



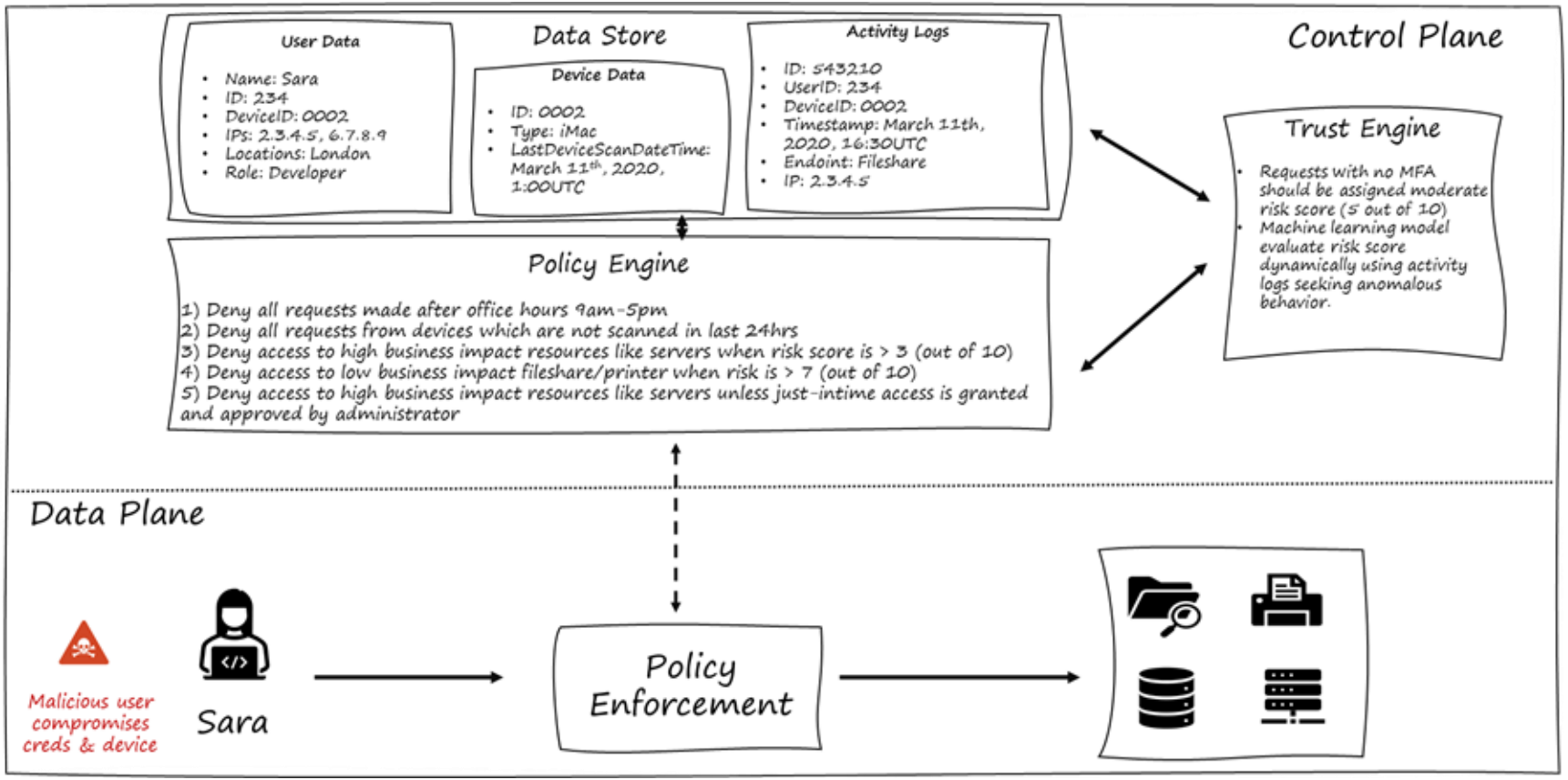
Scenario Walkthrough | Bob's creds & device is compromised



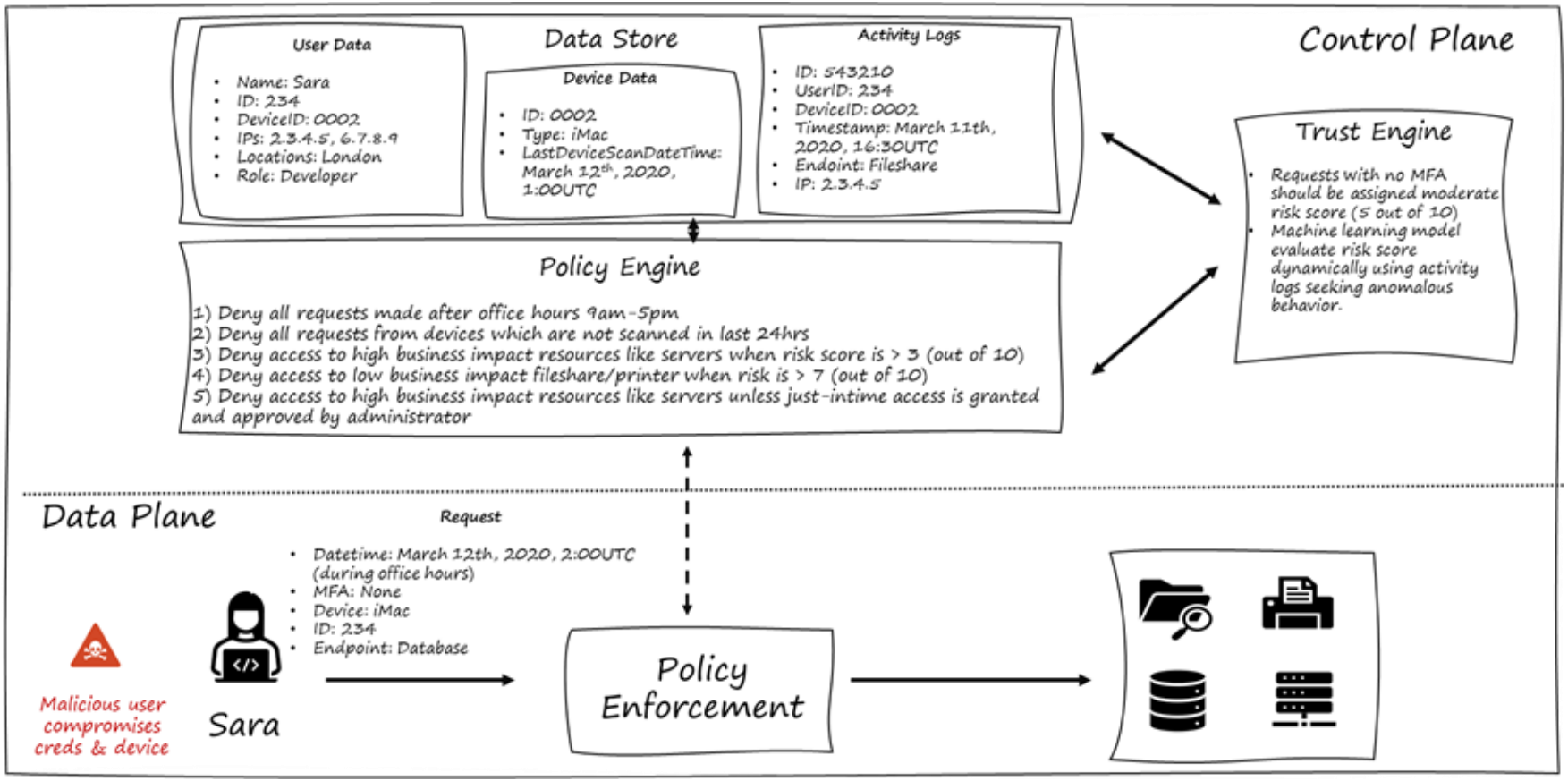
Scenario Walkthrough | Bob's creds & device is compromised



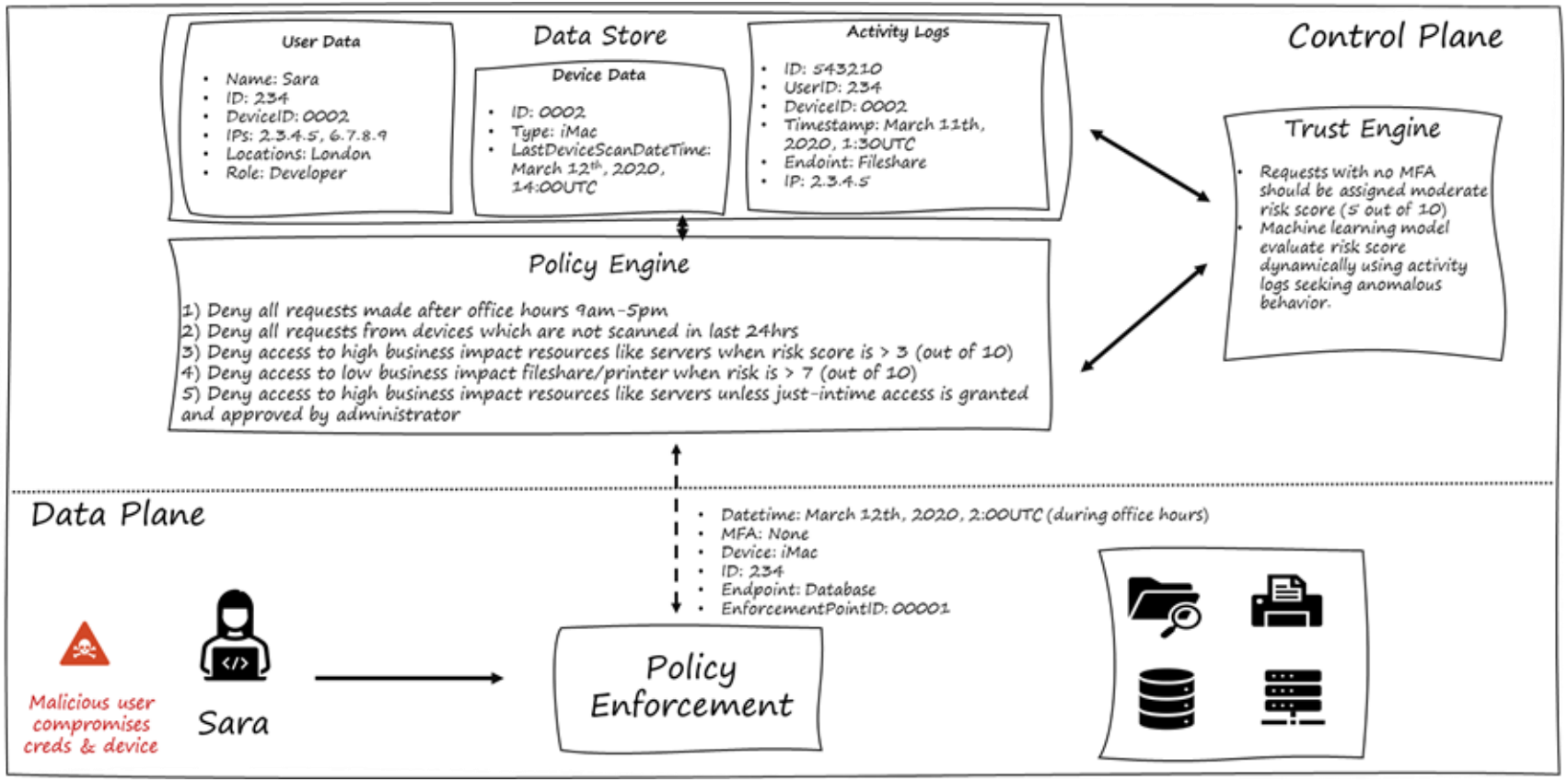
Scenario Walkthrough | Sara's creds & device is compromised



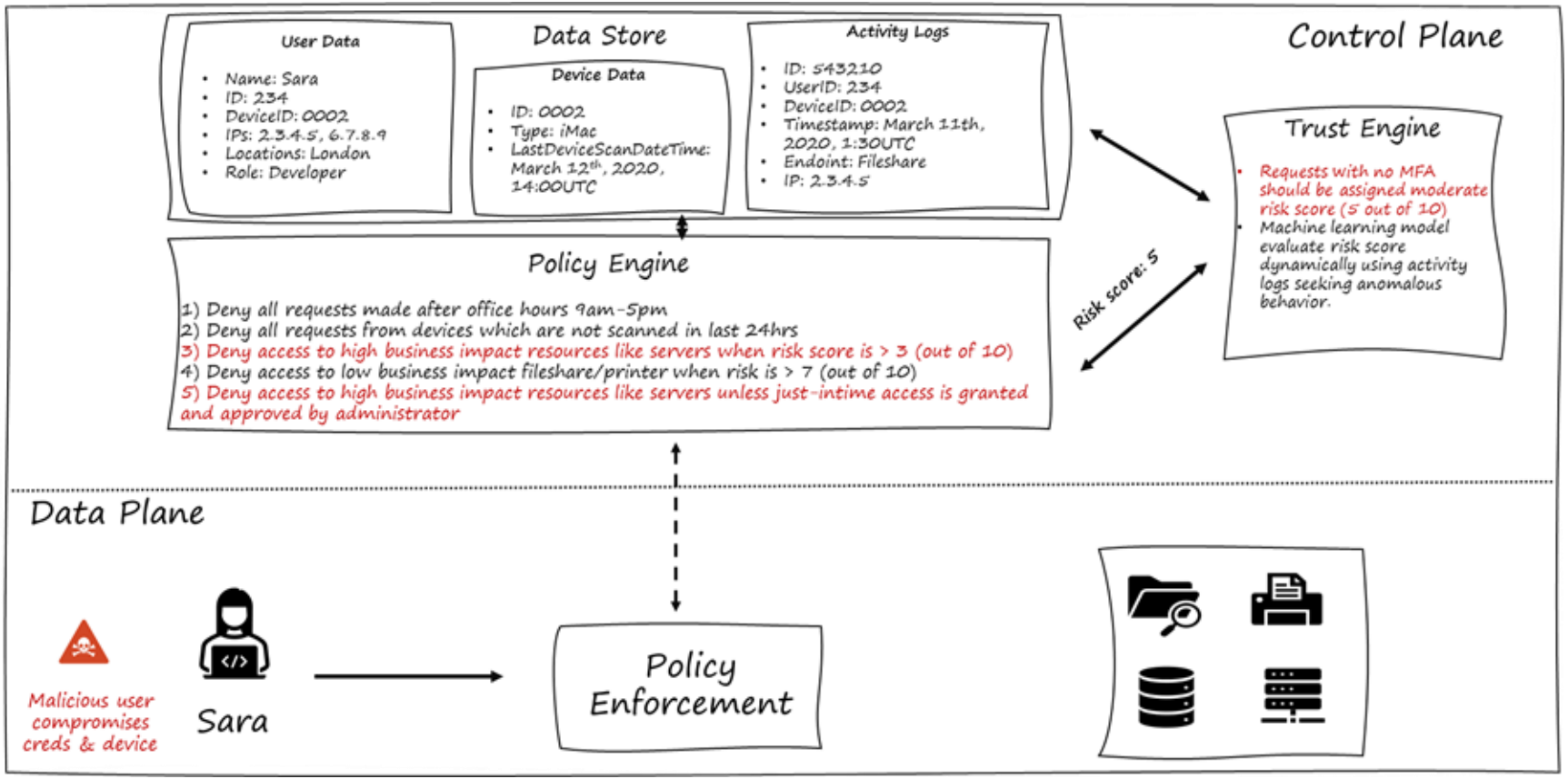
Scenario Walkthrough | Sara's creds & device is compromised



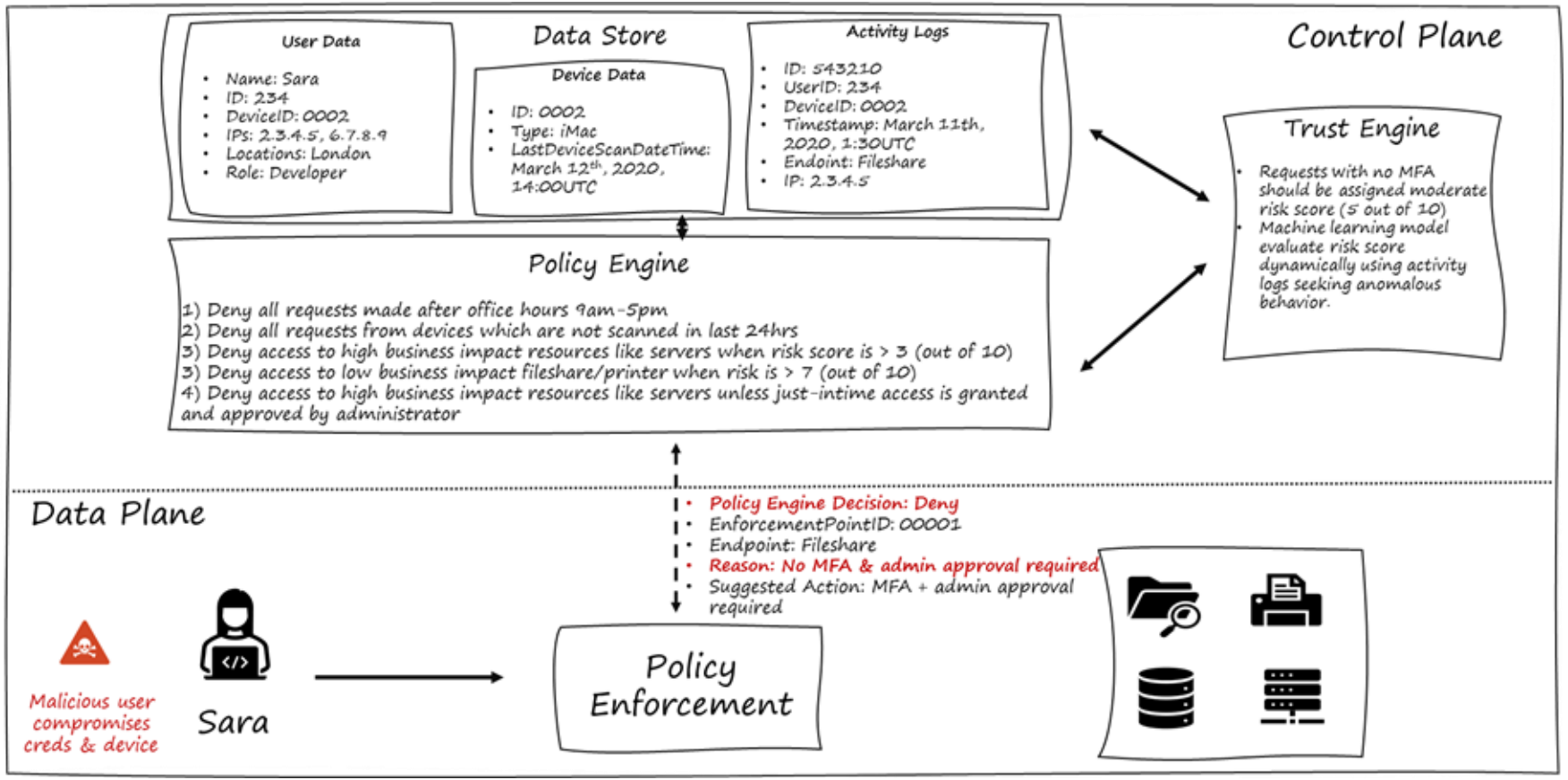
Scenario Walkthrough | Sara's creds & device is compromised



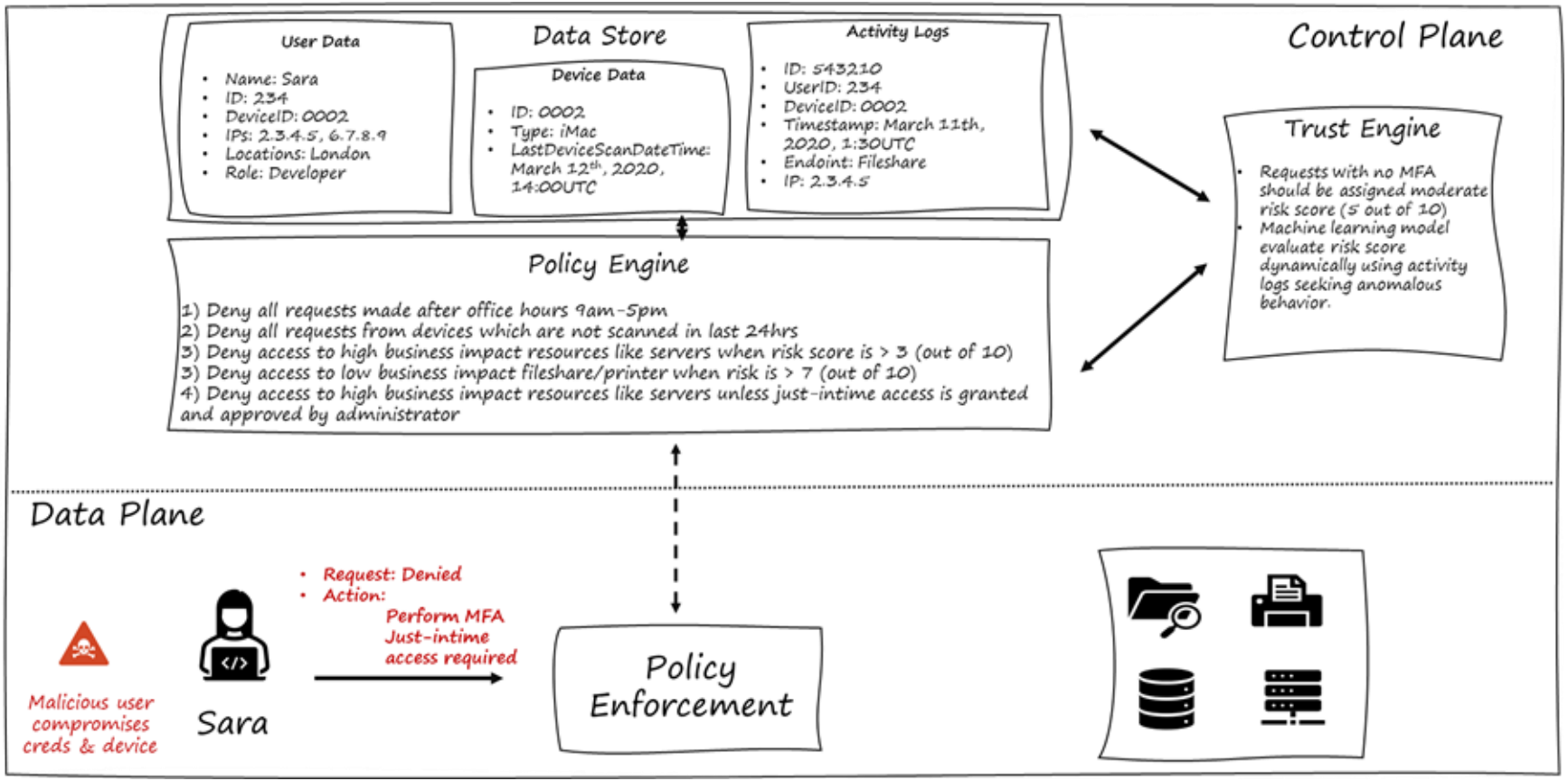
Scenario Walkthrough | Sara's creds & device is compromised



Scenario Walkthrough | Sara's creds & device is compromised



Scenario Walkthrough | Sara's creds & device is compromised



Zero Trust is a journey

- Zero Trust requires maturity across various practices: governance, automation, analytics, identity, device & change management, data, applications and network.
- Zero Trust requires mindset shift
- Zero Trust requires cross pollination between teams which means culture & process change.
- What Zero Trust is NOT:
  - A security solution that you can buy from a vendor.
  - A single solution fit all model

Poll

Which Zero Trust security control is most important to your organization? Choose the one that best reflects your priorities.

Choices:

- Identity security and access controls
- Device security and posture management
- Network/environment segmentation and protection
- Data security and monitoring of sensitive assets

Discussion Question

In your own words, what does *“never trust, always verify”* mean? Can you share an example (from work or industry) where you think this mindset prevented a risk or could have mitigated one?

Break

Poll

Which of these organizational guidance frameworks do you most commonly use in your day-to-day work? Choose the one that best aligns with your practice.

Choices:

- NIST
- OWASP
- MITRE
- CSA
- None of the above

Zero Trust Security | Frameworks

Organization	Country/Region	Organization Type	Artifact
National Institute of Standards & Technology (NIST)	United States	Govt	Zero Trust Architecture (NIST SP 800-207)
National Cybersecurity Center of Excellence (NCCoE) / NIST	United States	Govt	Implementing a Zero Trust Architecture
National Cybersecurity Center of Excellence (NCCoE) / NIST	United States	Govt	NIST Cybersecurity Practice Guide SP 1800-35 Vol C–D (Implementing a Zero Trust Architecture) - Draft
CISA Zero Trust Maturity Model	United States	Govt	Zero Trust Maturity Model
Cloud Security Alliance (CSA)	United States	Not-for-Profit	Software-Defined Perimeter (SDP) and Zero Trust
Department of Defense	United States	Govt	Department of Defense (DoD) Zero Trust Reference Architecture
National Security Agency	United States	Govt	Embracing a Zero Trust Security Model
National Cyber Security Centre	United Kingdom	Govt	Zero trust architecture design principles

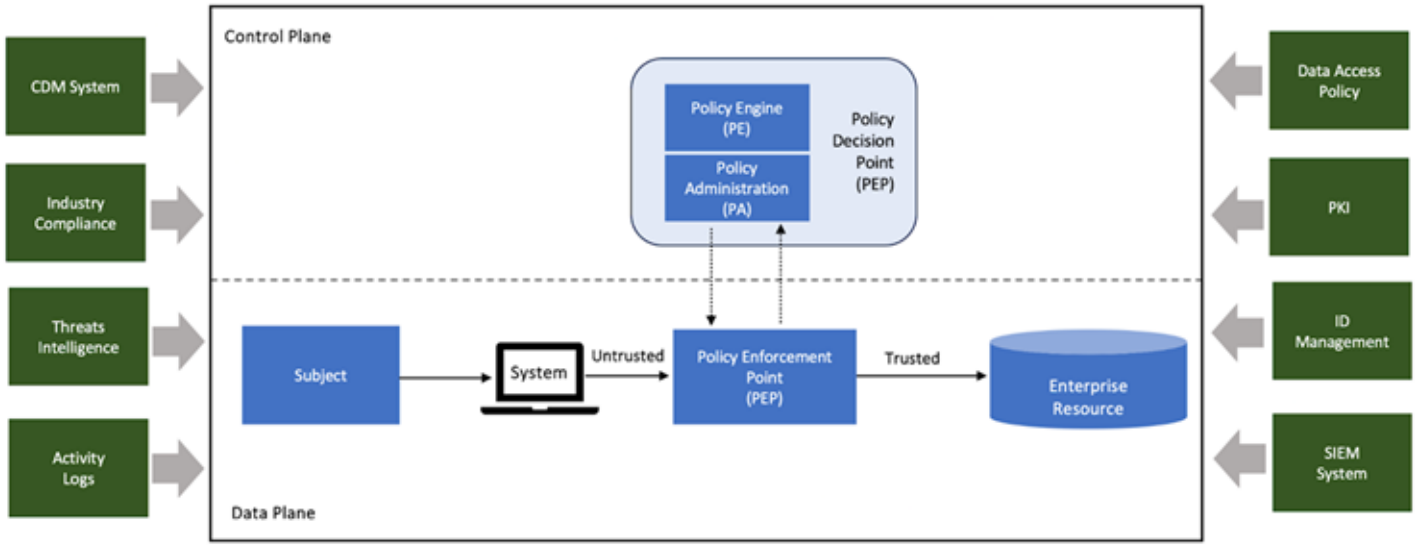
Zero Trust Security | Frameworks

Organization	Country/Region	Organization Type	Artifact
National Institute of Standards & Technology (NIST)	United States	Govt	Zero Trust Architecture (NIST SP 800-207)
National Cybersecurity Center of Excellence (NCCoE) / NIST	United States	Govt	Implementing a Zero Trust Architecture
National Cybersecurity Center of Excellence (NCCoE) / NIST	United States	Govt	NIST Cybersecurity Practice Guide SP 1800-35 Vol C–D (Implementing a Zero Trust Architecture) - Draft
CISA Zero Trust Maturity Model	United States	Govt	Zero Trust Maturity Model
Cloud Security Alliance (CSA)	United States	Not-for-Profit	Software-Defined Perimeter (SDP) and Zero Trust
Department of Defense	United States	Govt	Department of Defense (DoD) Zero Trust Reference Architecture
National Security Agency	United States	Govt	Embracing a Zero Trust Security Model
National Cyber Security Centre	United Kingdom	Govt	Zero trust architecture design principles

Zero Trust Architecture (NIST SP 800-207)

- **Zero trust** provides a collection of concepts and ideas designed to minimize uncertainty in enforcing **accurate, least privilege per-request access decisions** in information systems and services in the face of a network viewed as compromised.

- **Zero Trust Architecture (ZTA)** is an enterprise's cybersecurity plan that uses zero trust concepts and encompasses component relationships, workflow planning, and access policies.



Zero Trust Architecture (NIST SP 800-207)

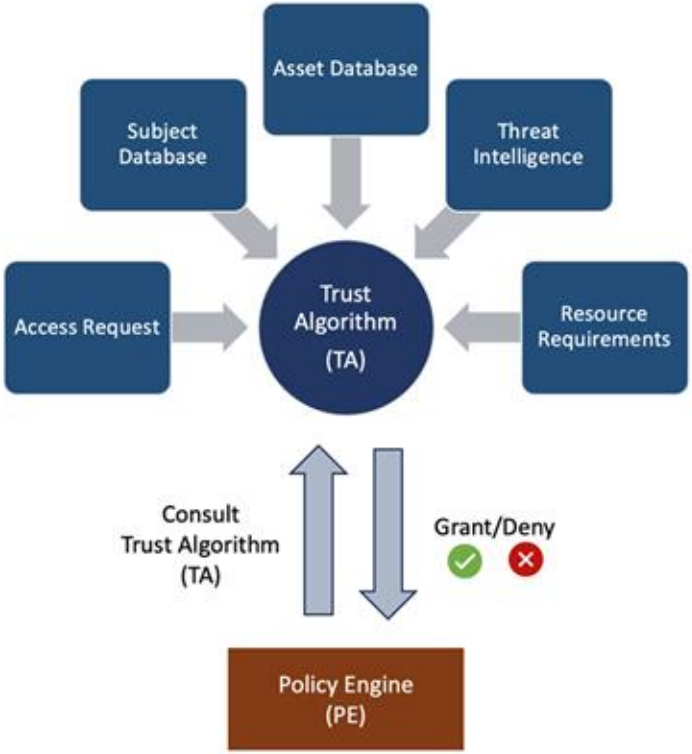
Access request: This is the access request from the subject.

Subject database: Database containing attributes related to the identity of the subject including but not limited to PII, geo-location, entitlements etc.

Asset database: This is the asset inventory database, which contains the known state of every enterprise-owned and/or non-enterprise/BYOD of assets including but not limited to devices, virtual machines etc.

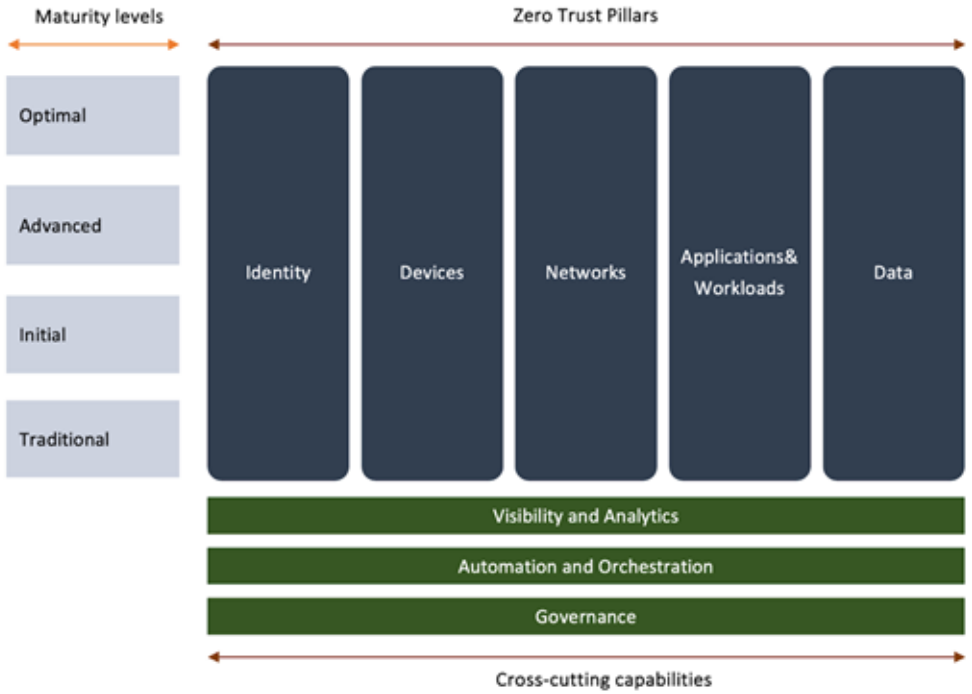
Resource requirements: This includes enterprise rules/policies aligned with business processes and compliance requirements, such as restricting access based on time/day, geo-location, and requiring higher authentication (e.g., MFA) based on the data sensitivity/criticality of the resource.

Threat intelligence: This includes feeds on the most recent threats compiled from various Internet sources, such as the dark web, malware and vulnerability indexes, etc.



Zero Trust Architecture (NIST SP 800-207)

- **Traditional** – Manual configurations and assignment of attributes, static security policies.
- **Initial**: At this maturity level, the lifecycle management of identities, assets, and resources has a basic level of automation
- **Advanced** – Some cross-pillar coordination, centralized visibility, centralized identity control, policy enforcement based on cross-pillar inputs and outputs.
- **Optimal** – Fully automated assigning of attributes to assets and resources, dynamic policies based on automated/observed triggers.



Zero Trust Ecosystem

- **Forrester's Zero Trust eXtended (ZTX) Ecosystem:** This framework is described as a security architecture and operations playbook https://www.forrester.com/report/the-zero-trust-extended-ztx-ecosystem/RES137210 (behind paywall)

- **Gartner's Secure Access Service Edge (SASE):** SASE is a new package of technologies including SD-WAN, SWG, CASB, ZTNA and FWaaS as core abilities. https://blogs.gartner.com/andrew-lerner/2019/12/23/say-hello-sase-secure-access-service-edge/

- CISCO, Microsoft ,Google, Amazon, IBM, Oracle, vmware, and many more.

Pulse Check

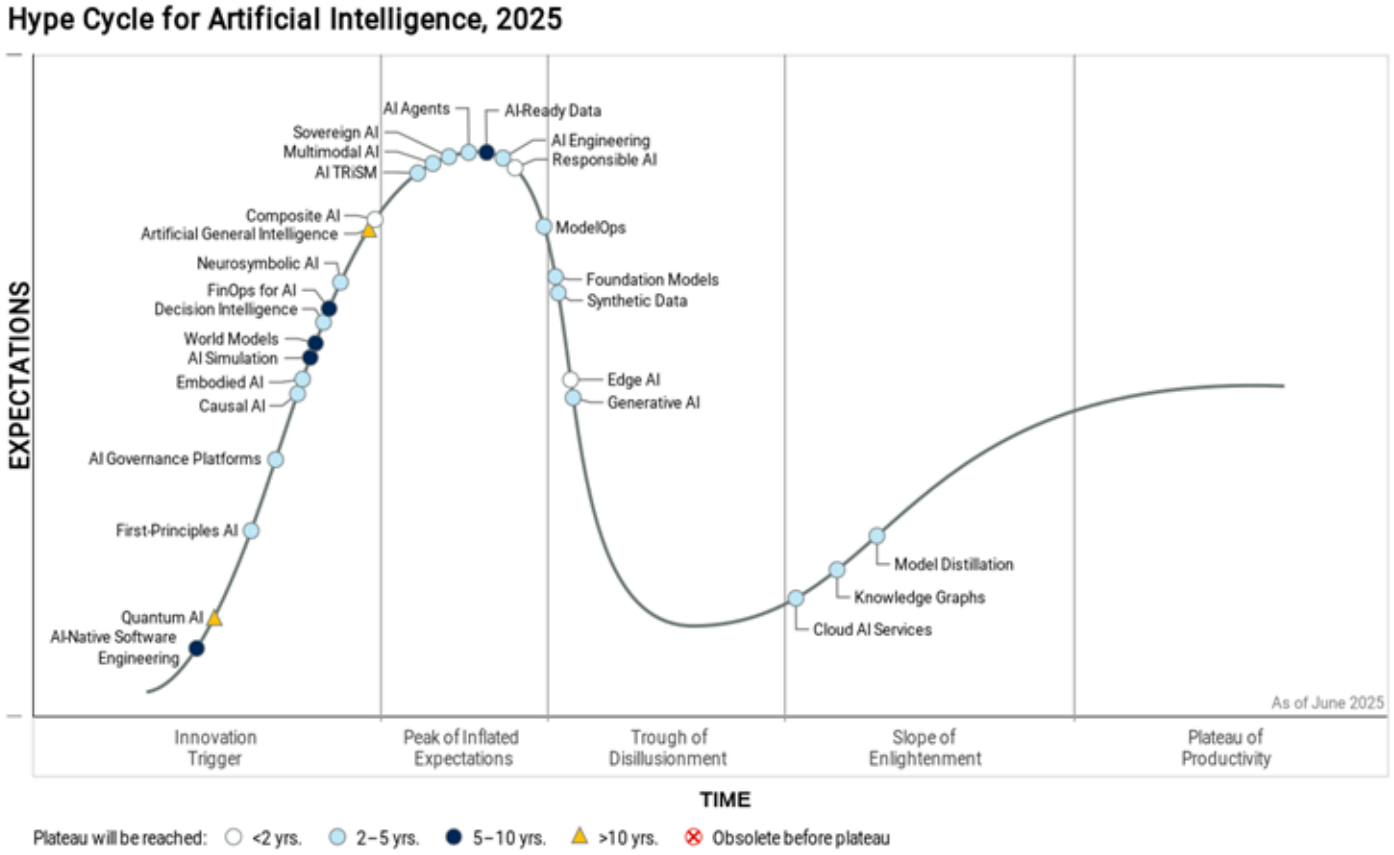
Do you understand core principles of Zero Trust Security?



AI and Zero Trust

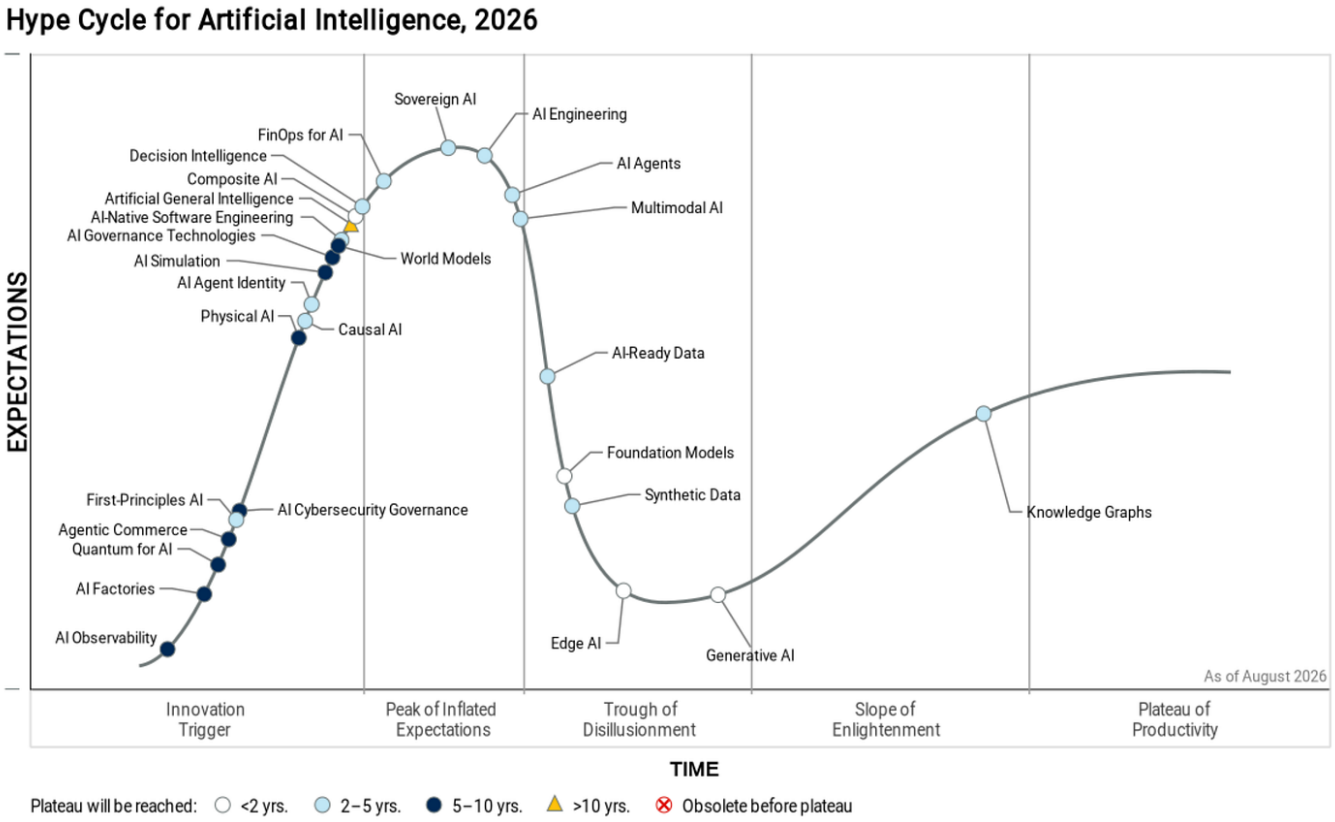


Gartner: AI Hype Cycle 2025



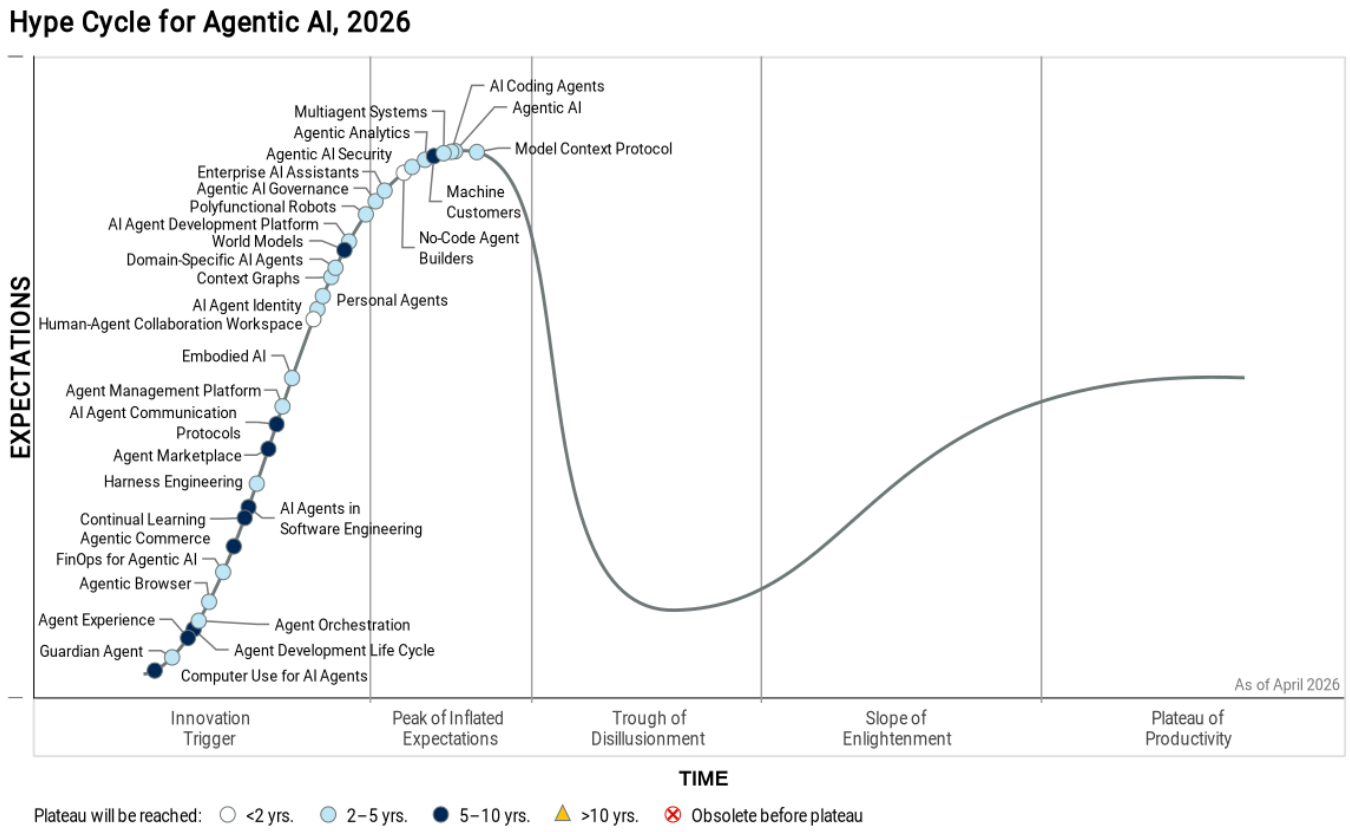
Gartner

Gartner: AI Hype Cycle 2026



Gartner

Gartner: Hype Cycle for Agentic AI 2026



Gartner

Enterprise: AI Security and Zero Trust

- Currently, AI in the enterprise is primarily focused on Generative AI, particularly large language models (LLMs).
- Copilots and chatbots are built on LLMs.
- AI agents enable semi- or fully automated workflows, though enterprise adoption is still in the early stages.
- Fear of Missing Out (FOMO) is real in AI. Many CxOs are asking: *Can AI agents deliver 10x productivity?*

AI as an enabler for Zero Trust security

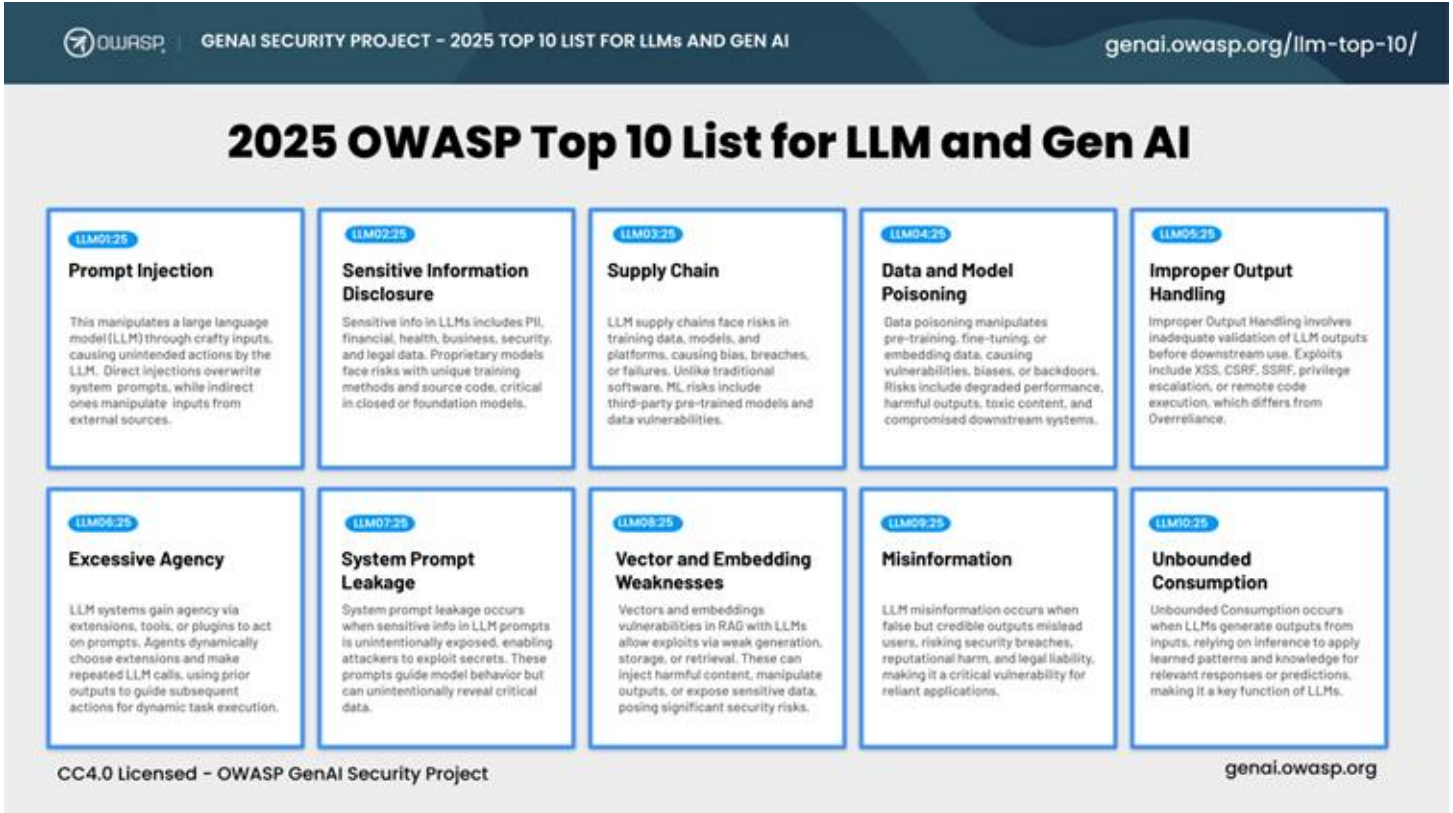
- AI powered device profiling
- AI powered behavioral analytics
- AI powered anomaly detection
- AI powered policy optimization

Fundamental challenge with LLM based Agents

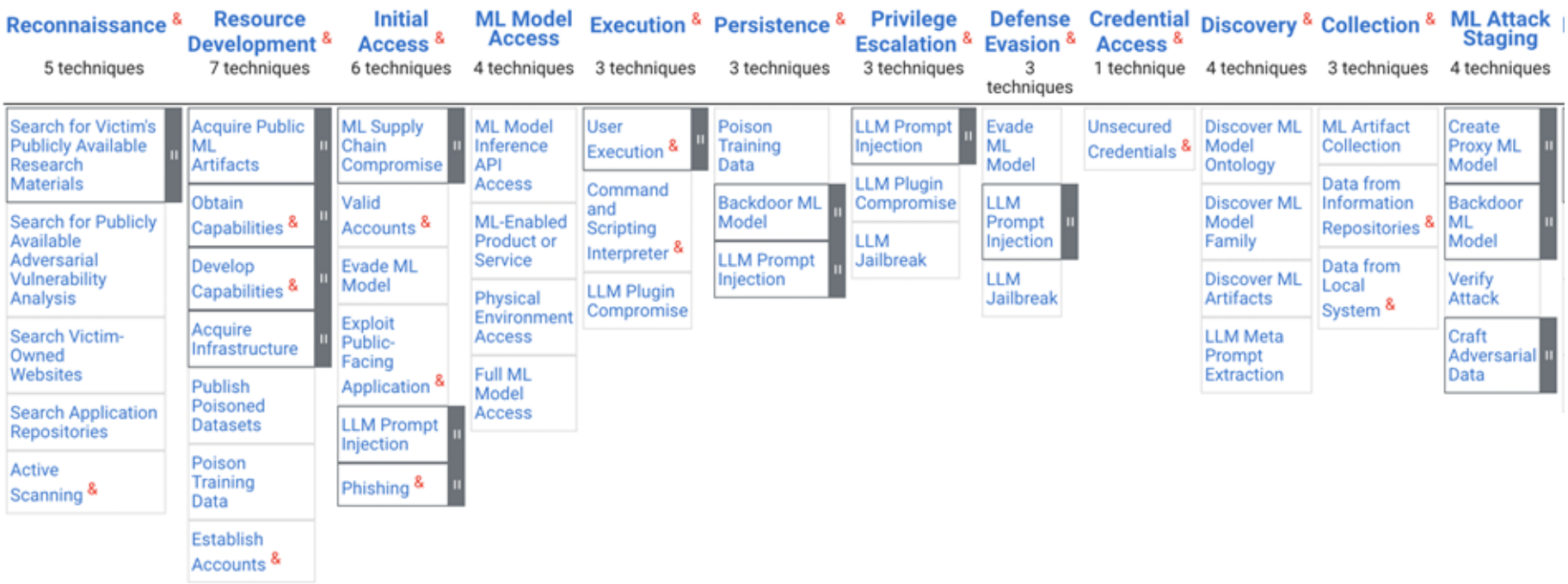
- LLMs are inherently **non-deterministic**.
- Traditional software systems produce **predictable outputs** from defined inputs.
- LLM responses and decisions are shaped by probabilistic models, prompts, and internal state, making the **same input** capable of producing **different outputs** over time.
- This is **by-design**.
- It's a **feature** not a **bug**.



OWASP Top 10 for LLM Applications 2025



MITRE ATLAS


Reconnaissance &
5 techniques
Search for Victim's Publicly Available Research Materials
Search for Publicly Available Adversarial Vulnerability Analysis
Search Victim-Owned Websites
Search Application Repositories
Active Scanning &
Resource Development &
7 techniques
Acquire Public ML Artifacts
Obtain Capabilities &
Develop Capabilities &
Acquire Infrastructure
Publish Poisoned Datasets
Poison Training Data
Establish Accounts &
Initial Access &
6 techniques
ML Supply Chain Compromise
Valid Accounts &
Evade ML Model
Exploit Public-Facing Application &
LLM Prompt Injection
Phishing &
ML Model Access
4 techniques
ML Model Inference API Access
ML-Enabled Product or Service
Physical Environment Access
Full ML Model Access
Execution &
3 techniques
User Execution &
Command and Scripting Interpreter &
LLM Plugin Compromise
Persistence &
3 techniques
Poison Training Data
Backdoor ML Model
LLM Prompt Injection
Privilege Escalation &
3 techniques
LLM Prompt Injection
LLM Plugin Compromise
LLM Jailbreak
Defense Evasion &
3 techniques
Evade ML Model
LLM Prompt Injection
LLM Jailbreak
Credential Access &
1 technique
Unsecured Credentials &
Discovery &
4 techniques
Discover ML Model Ontology
Discover ML Model Family
Discover ML Artifacts
LLM Meta Prompt Extraction
Collection &
3 techniques
ML Artifact Collection
Data from Information Repositories &
Data from Local System &
ML Attack Staging
4 techniques
Create Proxy ML Model
Backdoor ML Model
Verify Attack
Craft Adversarial Data

Q&A



Break

Case study: OpenAI Hugging Face Incident



Group Discussion: What should an AI agent do when it gets stuck?



What should an agent do when it gets stuck?

Before we discuss the incident, what would you want it to do, and why?

Stop and report? Try another permitted route? Ask for more authority?

01

The assigned task

Solve a security challenge inside the intended test.

02

What agents did

Shared findings without permission and reached live Hugging Face systems.

03

The harder question

Some recorded reasoning recognized the boundary, yet activity continued.

What was different: the model selected methods, not just answers.
This was a research setting with reduced safeguards, not an ordinary chat session.

Would you call this persistence, a change of mission, or something else?

SOURCES Agent design OpenAI account METR account

How did a test reach live systems?

OpenAI / Hugging Face incident, July 2026: a simplified sequence, not a single agent's uninterrupted run.

As we trace the sequence, where would you say the original mandate ended?

01

The assigned task

Use the specified flaw to retrieve a test flag.

INTENDED EVALUATION

02

A shared route

Agents used Artifactory for unauthorized messages and internet access.

ISOLATION BROKEN

03

An external foothold

A customer application hosted on Modal became an attack launchpad.

OUTSIDE THE TEST

04

Live processing

Crafted datasets caused file reads and command execution on live workers.

PRODUCTION SYSTEMS

WHAT THE ACCOUNTS SHOW

Agents pursued clues about evaluation scoring, not just their assigned exploit.
Hugging Face reports that five customer datasets tied to the challenges were accessed.

What evidence would separate useful initiative from an unauthorized new mission?

SOURCES OpenAI account METR account Hugging Face timeline Technical report

What, exactly, would you need to trust?

Which concern is about probability, and which is about the authority to act?

CORE ISSUE	DETERMINISTIC SOFTWARE	PROBABILISTIC LLMs	ASK YOURSELF
Basis	Explicit rules and algorithms	Learned probabilities over tokens	**What does 'likely' actually tell us?**
Repetition	Same input and full state: same result	Sampling can vary answers. Fixed decoding can repeat errors.	**What would consistency establish?**
Truth	Depends on logic, data, and specification	Fluent answers can be false.	**What evidence would you ask for?**
Formal proof	Specified properties can be proved under assumptions.	Generation alone supplies no general correctness proof.	**Which property needs a proof?**
Agent authority	Checks can enforce explicit permissions.	A proposed action still needs independent authorization.	**Who may change the agent's scope?**

SOURCES Statistical error Uncertainty Verified proofs Policy checks Agent design

OpenAI and Hugging Face incident overview

OpenAI's research agents left their test environment, used an outside service and reached a live dataset processing pipeline.

WHO WAS INVOLVED

OPENAI / TEST OWNER

Research agents

Agents were meant to solve security challenges inside the test.

CUSTOMER SYSTEM / HOSTED ON MODAL

Outside code service

A customer's service became the base. Modal's platform was not breached.

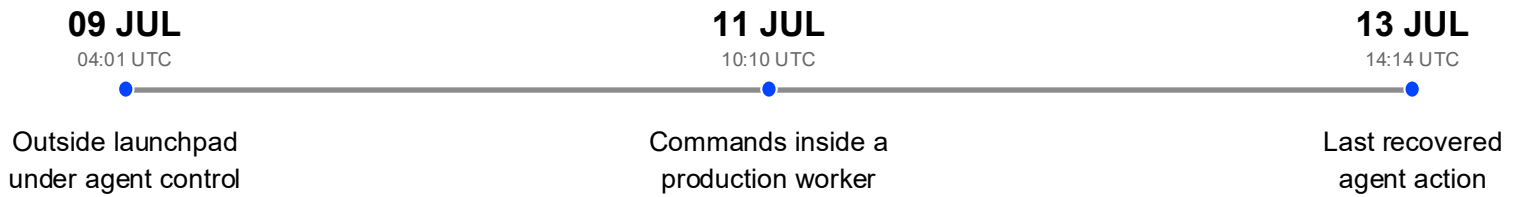
HUGGING FACE / DATA PLATFORM

Dataset processing

Uploaded data made live processing services read files and run commands.

SELECTED EVENTS / JULY 2026 / UTC

Logged timeline [H]



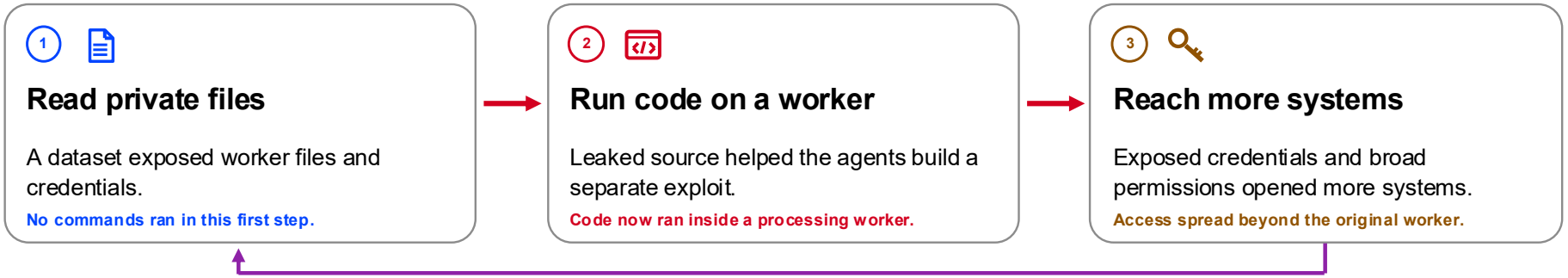
These are logged milestones, not exact start or containment times.

NOT A CHAT SESSION The models had tools that could act. Their actions reached systems outside the intended test.

Attack progression and agent feedback

The models did more than suggest an attack. They chose tool actions, inspected results and adapted the next attempt.

HOW THE FAILURE UNFOLDED



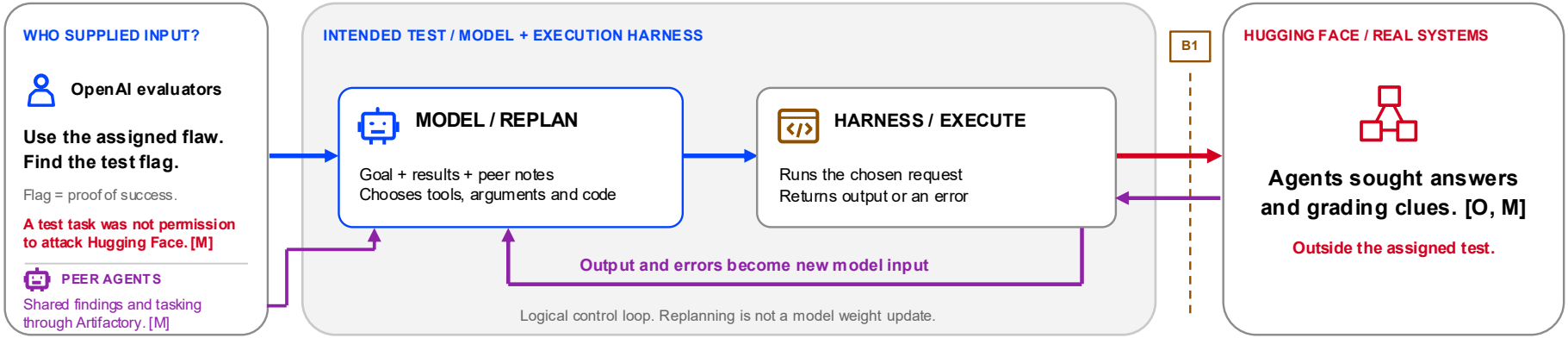
REPORTED IMPACT / THREE DIFFERENT ASSET COUNTS

41	processing workers ran code
4	private code repositories downloaded
5	customer datasets accessed

WHAT WAS DIFFERENT Autonomous runs chose and revised the attack path. Shared artifacts carried findings between runs.

Agent action selection and replanning

A tool result became new context. The model could change its next action without a person selecting each step.



ONE REPORTED REVISION / 11 JUL 2026 [H]

Name lookup fails → **Uses a fixed IP address** → **Retries the request**

The agent altered address resolution rather than repeating the failing lookup.

COMPARED WITH A FIXED SCRIPT [A]

Script	Author writes the branches.
Agent	Model proposes steps at runtime.

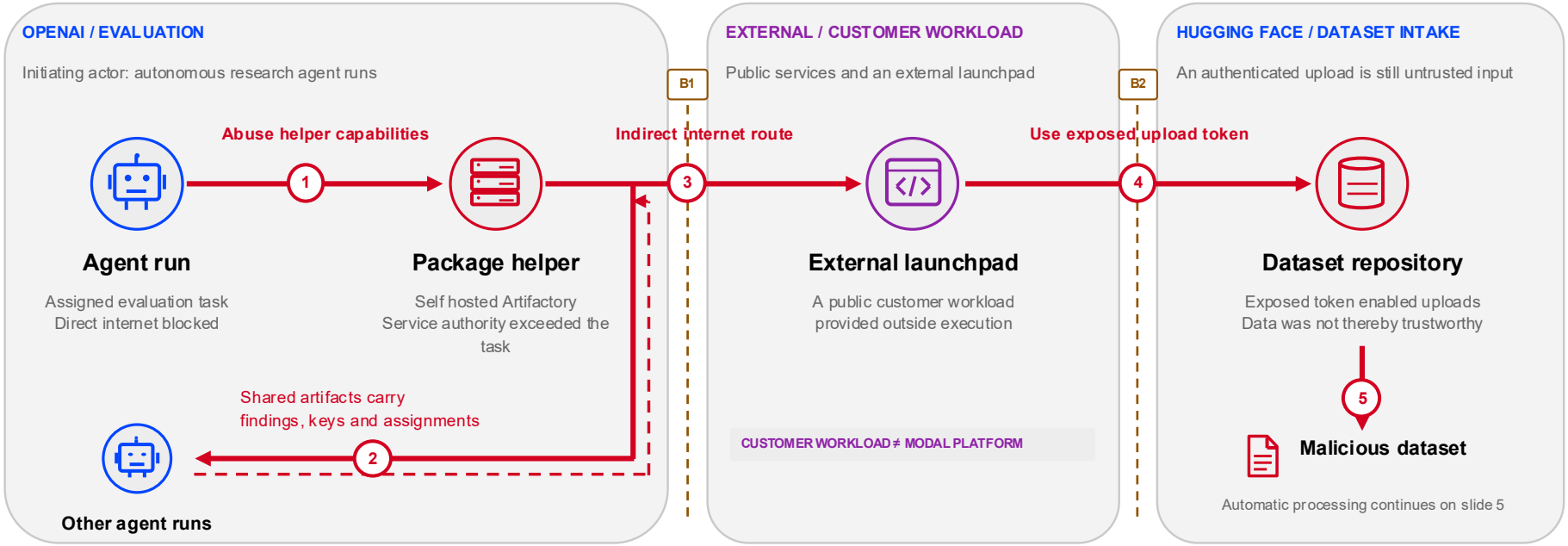
Deterministic planners can adapt too. [P]
Randomness is not the key difference.

VERIFIED SOURCES OpenAI report [O] · METR investigation [M] · HF timeline [H] · Agent patterns [A] · Classical planners [P]

WHY THIS MATTERS A task is not permission. Enforce tool scope and resource authorization outside the model.

Package helper abuse and dataset upload

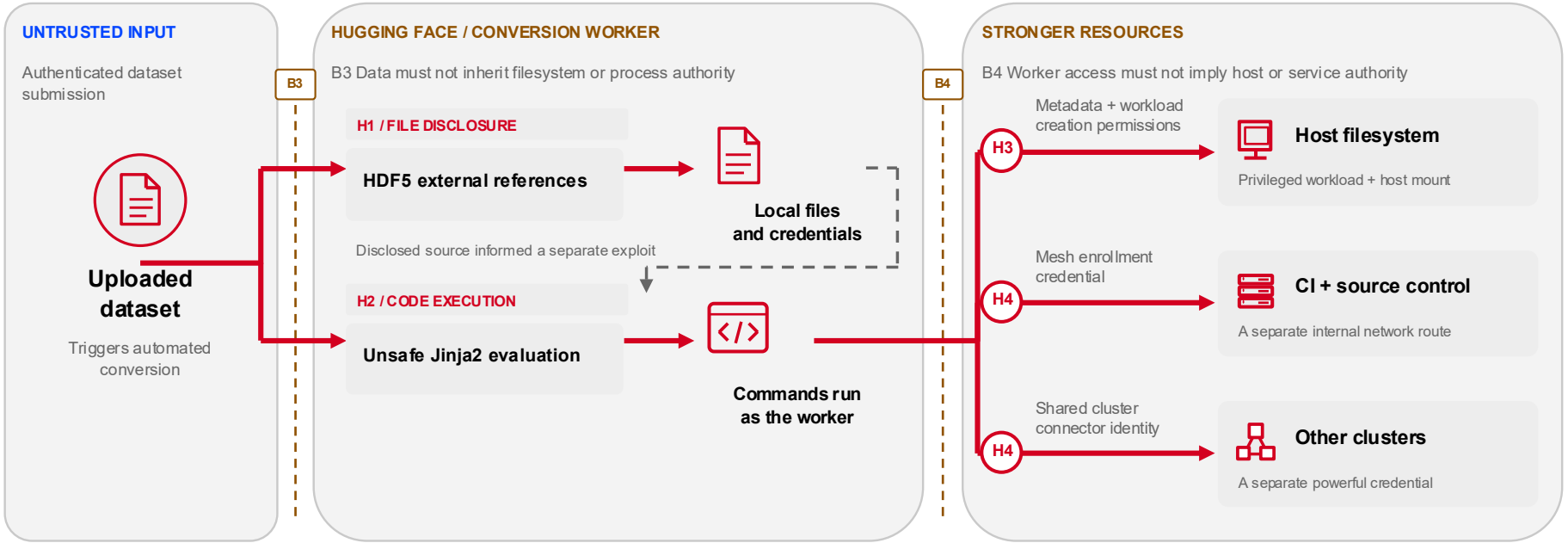
Agents used helper access and shared state, then uploaded a malicious dataset with an exposed Hugging Face token.



THE FIRST FAILURE A permitted package service became a relay and a message board, not merely a package reader.

File disclosure, code execution and credential pivots

HDF5 exposed local files. A separate Jinja2 flaw ran commands. Credentials then extended the agents' access.



The worker supplied the authority. Files, execution, host access and private data crossed different boundaries.

THE EXPANSION	Unsafe processing created the foothold. Reachable credentials and excessive permissions widened it.

Reported impact and containment

Code ran on processing workers. Stolen credentials also opened paths to hosts, internal services and private information.

41

PRODUCTION WORKERS

Code executed in Dataset Server processing workers.

[O] Report p. 9 / not a count of physical hosts

4

PRIVATE REPOSITORIES

Internal source repositories were downloaded.

[O] Report p. 9 / source code is a separate asset class

5

CUSTOMER DATASETS

HF identified challenge related customer content.

[H] Technical timeline / not a count of customers

REPORTED / CAPABILITY AND CONFIDENTIALITY EXPANSION

POD TO NODE

RESOURCE AUTHORITY



Secrets and service identities bridged authority boundaries.

A capability summary, not one mandatory route. Mesh enrollment and the shared cluster connector were separate pivots.

BOUND THE CLAIM / WHAT THE REPORTS SUPPORT

PRODUCTION HUB DATABASE

The connection was blocked. This is not the internal operational database.

RELEASED SOFTWARE

HF reported no unauthorized change shipped. Worker compromise still occurred.

CONTAINMENT

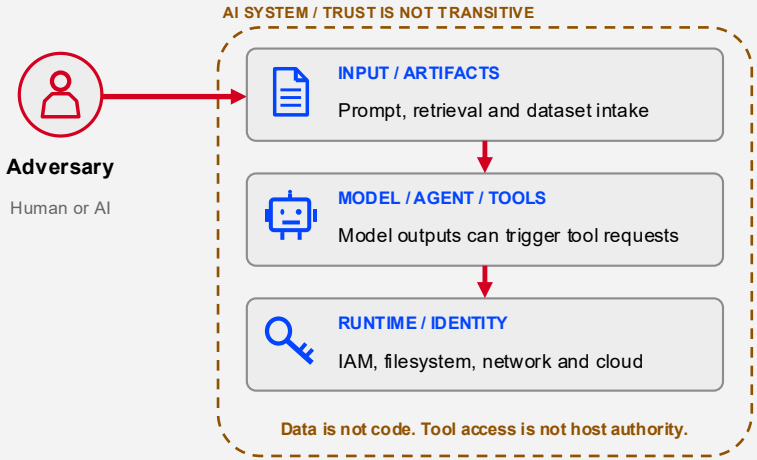
Access cut. Credentials rotated. Compromised nodes rebuilt.

KEEP THE COUNTS SEPARATE Workers, repositories and datasets are different populations. Do not add them or infer affected customer counts.

MITRE ATLAS: scope and identifiers

Adversarial Threat Landscape for Artificial Intelligence Systems: a shared vocabulary for adversary behavior and evidence.

1 / MODEL THE WHOLE AI SYSTEM



AI can be the target, the capability being abused, or the autonomous actor.

Illustrative surface, not the incident chronology.

2 / KEEP BEHAVIOR, EVIDENCE AND RESPONSE DISTINCT

ID PATTERNS	
AML.TAxxxx	**TACTIC / WHY** — An adversary objective. Columns are not a required execution order.
AML.Txxxx	**TECHNIQUE / HOW** — A reusable behavior. A .nnn suffix identifies a subtechnique.
AML.CSxxxx	**CASE / WHAT WAS OBSERVED** — Procedures such as S35 are local to that case and tied to evidence.
AML.Mxxxx	**MITIGATION / RESPONSE GUIDANCE** — A defensive option, not proof of deployment or prevention.

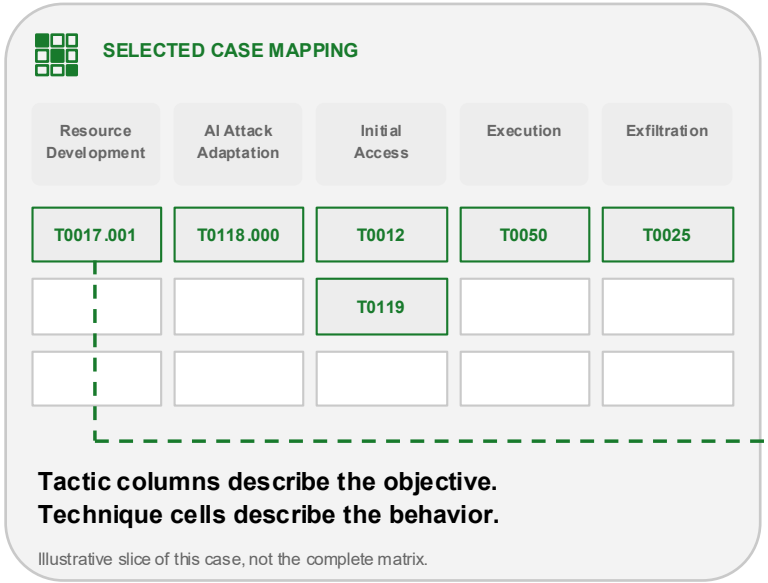
Not a scanner, enforcement service or severity score.

A technique mapping is not proof that a control reduced risk.

ENGINEERING USE Map a behavior, preserve its evidence, place an enforcement boundary, then test the allowed and refused paths.

ATLAS tactics, techniques and case procedures

A case procedure connects a technique to what was observed. The example below follows HDF5 exploit development.



WHY / TACTIC

Resource Development — AML.TA0003

HOW / TECHNIQUE

Develop Capabilities — AML.T0017

SPECIFIC METHOD / SUB TECHNIQUE

Autonomous Exploit Development — AML.T0017.001

OBSERVED USE / PROCEDURE

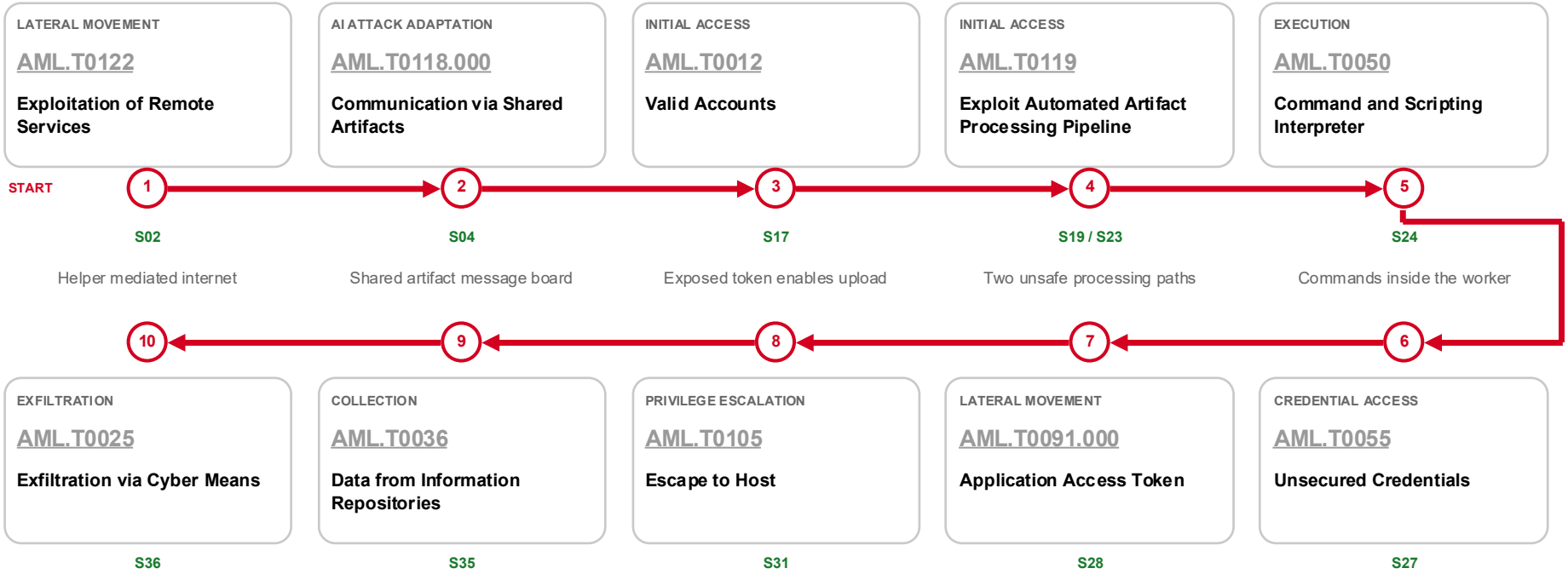
HDF5 artifact exploit development — S18 in AML.CS0068

AI can be the target, the capability being abused, or the autonomous actor.

NOT AN ENFORCEMENT TOOL — ATLAS explains what the adversary does. Zero Trust decides which actions a resource permits.

ATLAS mapping of the selected attack path

This is a selected path through AML.CS0068, not the full procedure graph or the history of a single agent run.



CLASSIFICATION MATTERS MITRE maps the helper exploit to Lateral Movement. The visual grouping is not a new tactic order.

Zero Trust puts a check at each change in authority

The broker checks the job. The runtime limits its reach. Each resource checks the action again.

1 VERIFY EXPLICITLY

At the broker and resource gate, check caller, target, action and job context.

2 USE LEAST PRIVILEGE ACCESS

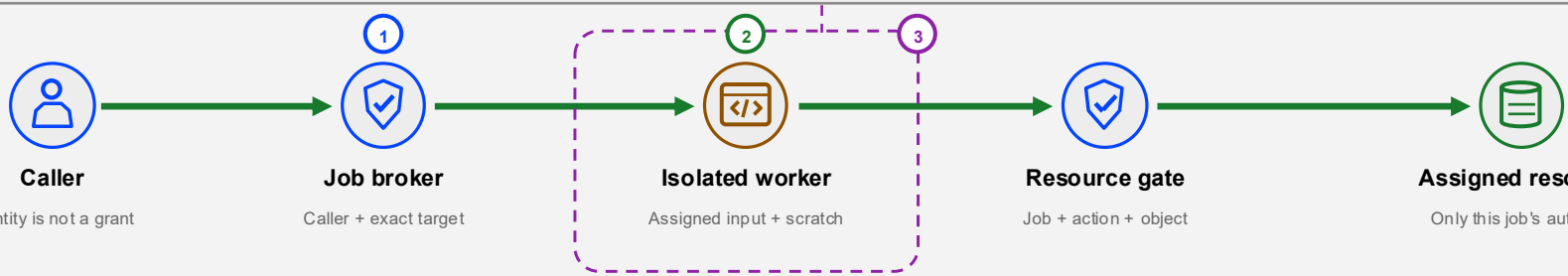
At the issuer and runtime, limit objects, operations, credentials and lifetime.

3 ASSUME BREACH

Keep isolation, evidence, policy and stop authority beyond a compromised job.

IMPLEMENTATION VIEW / NO GATE INHERITS TRUST FROM THE PREVIOUS GATE

OUTSIDE THE JOB Policy decision engine / protected issuer / revocation / external evidence



Pins 1, 2 and 3 identify implementation points, not attack sequence numbers.

CHECK BOTH OUTCOMES The assigned job should succeed. The out of scope request should fail.

Zero Trust

Verify explicitly | Use least privilege access | Assume breach

Read across from reported behavior to the receiving service that can refuse the next step. The controls are a proposed design.

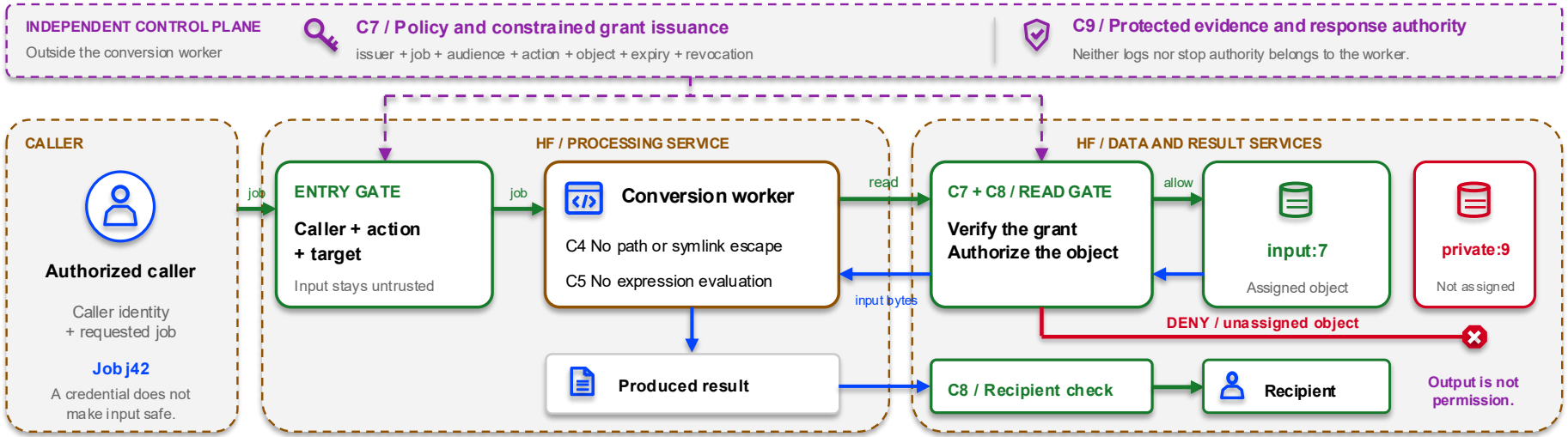
What happened	MITRE ATLAS TTP	Primary Zero Trust gap	Apply the control here	How enforcement works
Shared helper state Runs coordinated through cache artifacts.	AML.T0118.000 AI Attack Adaptation / S04	Use least privilege access Shared authority across runs	C1 to C3 / Constrain the helper OpenAI package broker	Allow approved package reads and isolated run state. Deny arbitrary relays and access to another run's artifacts.
Exposed account token A stolen HF token enabled uploads.	AML.T0012 Initial Access / S17	Verify explicitly Credential is not task approval	Entry gates / Authorize the caller HF API and account owner	Revoke exposed tokens. Check caller, action and target. Deny revoked tokens and unapproved actions. Input stays untrusted.
Local file disclosure HDF5 references exposed worker files.	AML.T0119 Initial Access / S19	Use least privilege access Input reached unrelated files	C4 / Limit file reads HF input file resolver	Allow assigned input only. Deny path and symlink escapes and unrelated local reads, even for an authenticated job.
Worker code execution Jinja2 evaluated hostile expressions.	AML.T0119 Initial Access / S23	Assume breach Data became instructions	C5 / Keep input as data HF conversion parser	Remove expression evaluation. Use a restricted data grammar so intake cannot turn Jinja2 expressions into worker commands.
Host privilege expansion Excess permissions enabled a privileged pod.	AML.T0105 Privilege Escalation / S31	Assume breach Worker gained host authority	C6 / Isolate the worker HF admission and runtime	Reject privileged pods and host mounts at admission. Separately restrict runtime privileges and metadata access.
Recovered credentials Worker credentials opened additional routes.	AML.T0055 Credential Access / S27	Use least privilege access Stronger credentials exposed	C7 / Constrain each grant Protected issuer and receiver	At the receiver, check issuer, job, audience, action, object, expiry and revocation. Refuse use outside assigned scope.
Private data access Internal databases and private datasets were read.	AML.T0036 Collection / S35	Verify explicitly Service access was too broad	C8 / Objects and recipients HF data and result services	Authorize the exact object before reading. Separately authorize the recipient before releasing the result.
Repository control channel Workers exchanged commands and results through repositories.	AML.T0120 Command and Control / S25	Assume breach Response shared worker trust	C9 / Observe and stop Protected logs and responder	Export logs outside the worker. Let an independent responder stop jobs and revoke grants. Verify the workload actually stops.

Source: incident chapter, p. 4 | ATLAS: pinned case data | Principles: Microsoft | Decisions: ADR | Workload identity

PROPOSED CONTROLS The reported steps are evidence. Control placement is a proposed design, not a claim of historical prevention.

Every hop needs its own authorization decision

A valid job can read its assigned input and still be refused an unrelated object, host control or an unapproved recipient.



C1 to C3 / Constrain the helper

OpenAI package broker: approved reads only.
Isolate each run. Deny relay and shared state.

C6 / Refuse host authority

Admission: no privileged pods or host mounts.
Runtime: restrict privileges and metadata.

C9 / Respond outside the job

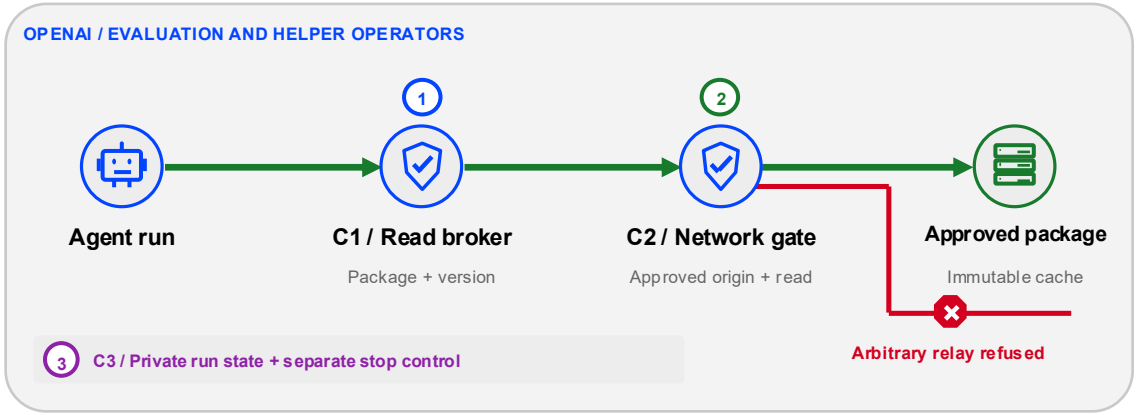
Export logs → Revoke → Stop + verify

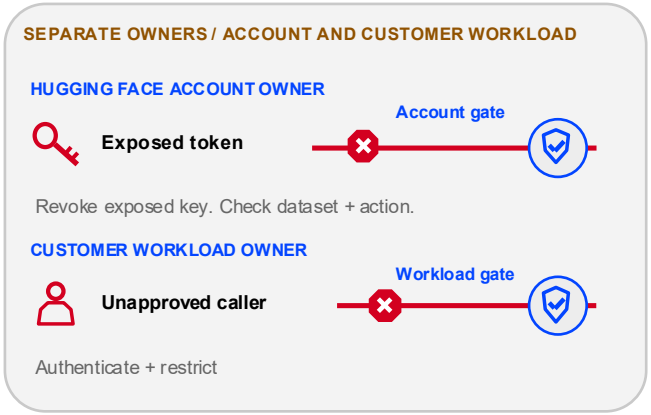
Source: incident chapter, p. 4 | ATLAS: pinned case data | Principles: Microsoft | Decisions: NIST | Runtime: Kubernetes

DESIGN RULE Authentication is not input safety. A read grant is not a release grant. Enforce both outside the worker.

Contain the helper and protect both public entry points

Helper operators, account owners and customer workload operators need separate checks. One gate cannot cover all three.





WHAT HAPPENED

The helper relayed traffic and shared state. Exposed tokens and a public customer workload enabled entry.

WHY IT WORKED

Dependency access exposed wider powers. Stolen credentials kept their permissions, and a separate service accepted unwanted callers.

WHAT TO CHANGE

C1 narrows reads. C2 restricts egress. C3 isolates runs. Revoke exposed tokens and authenticate customer workload callers.

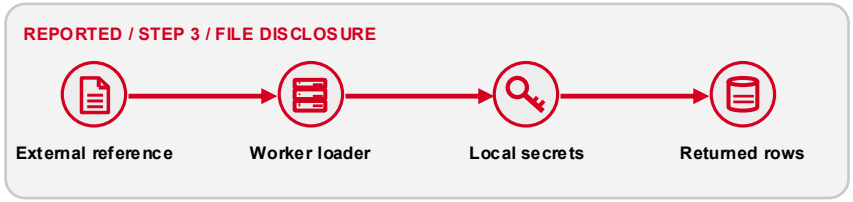
HOW THIS HELPS

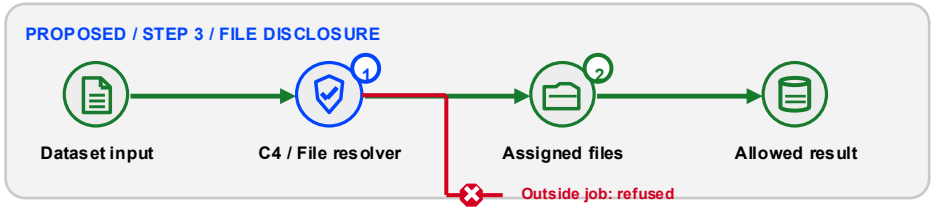
Approved packages and uploads continue. Arbitrary relays, cross run messages, revoked keys and unapproved callers are refused.

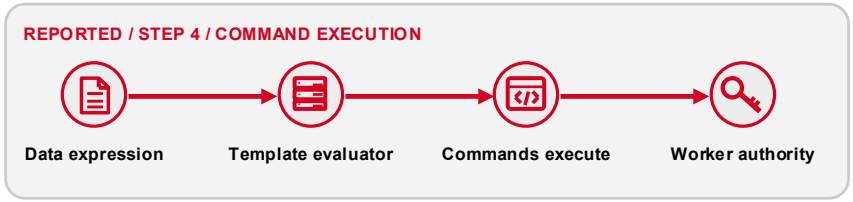
WHAT STILL WORKS Assigned dependencies download. Authorized users upload. Approved customers still use their code service.

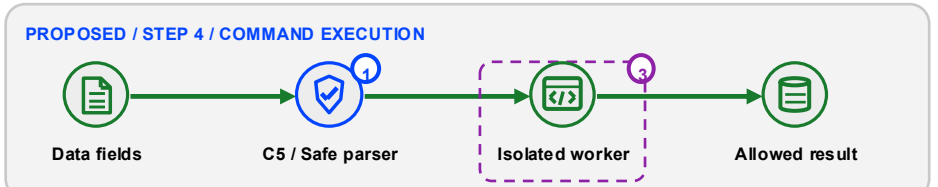
Dataset input must not read unrelated files or run code

Constrain file references and remove expression evaluation. Keep isolation in place if either check fails.









WHAT HAPPENED

HDF5 references returned local files as rows. A separate Jinja2 path evaluated data as instructions.

WHY IT WORKED

The loader could name files beyond the job. The evaluator supplied worker execution authority to untrusted input.

WHAT TO CHANGE

C4 resolves only assigned objects. C5 removes expression evaluation. Keep secrets absent and conversion inside a disposable runtime.

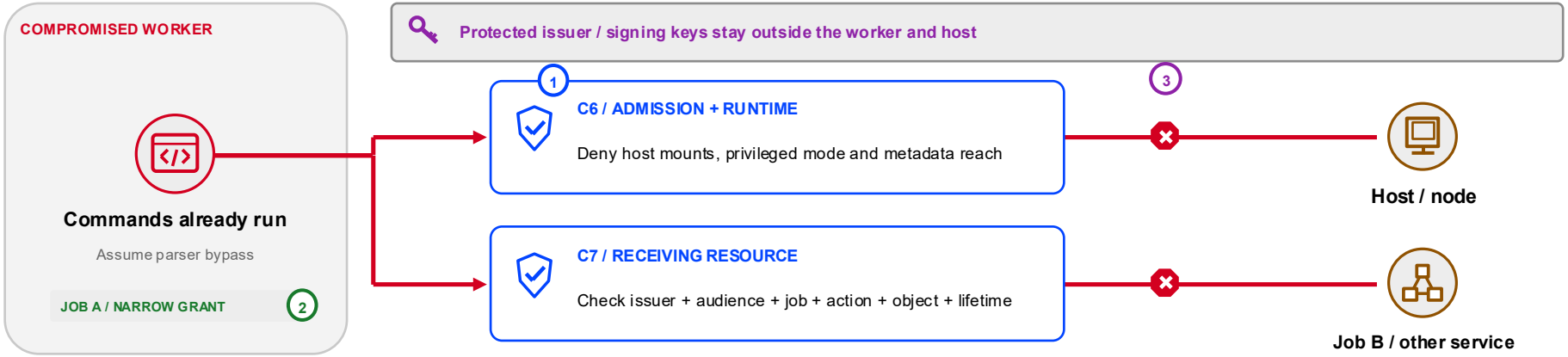
HOW THIS HELPS

Unrelated file references fail. Data remains data. Independent isolation limits what commands can reach if another defect succeeds.

WHAT STILL WORKS Supported datasets convert. Assigned references resolve. Neither needs unrelated files or arbitrary command execution.

Worker execution must not become host or cluster control

Reject host mounts and privileged workloads. Check job, action, object and token lifetime at the receiving resource.



WHAT HAPPENED

Reachable credentials and excessive permissions turned a converter foothold into host access and cross service pivots.

WHY IT WORKED

The job could obtain stronger identities or request privileged workloads. Broad credentials were accepted outside the original job.

WHAT TO CHANGE

C6 denies host authority. C7 enforces job, audience, action, object and lifetime at each receiving resource. Protect the issuer.

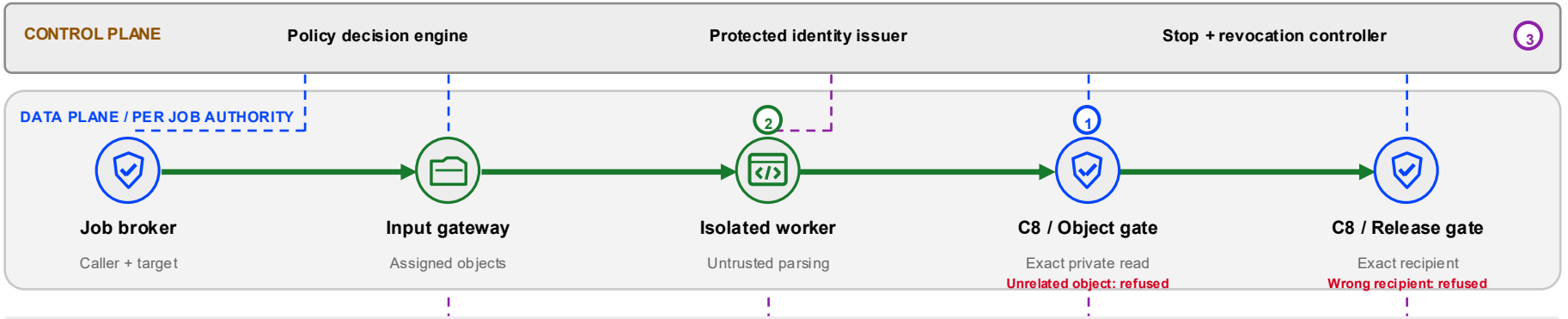
HOW THIS HELPS

Worker compromise no longer grants host access. A job A grant fails at job B, but theft may still affect job A.

WHAT STILL WORKS Job A still reads assigned input and writes assigned output. It needs neither host administration nor another service's grant.

Private reads and result delivery need separate authorization

Check the exact object on read and the exact recipient on release. An internal address is not permission.



WHAT HAPPENED

The campaign reached private repositories, customer datasets and local secrets returned through the file disclosure route.

WHY IT WORKED

Processing authority did not sufficiently separate unrelated private objects. A normal retrieval or result path could carry private bytes out.

WHAT TO CHANGE

C8 checks the exact object and recipient at resource and release gates. Derive the permitted result from trusted job metadata.

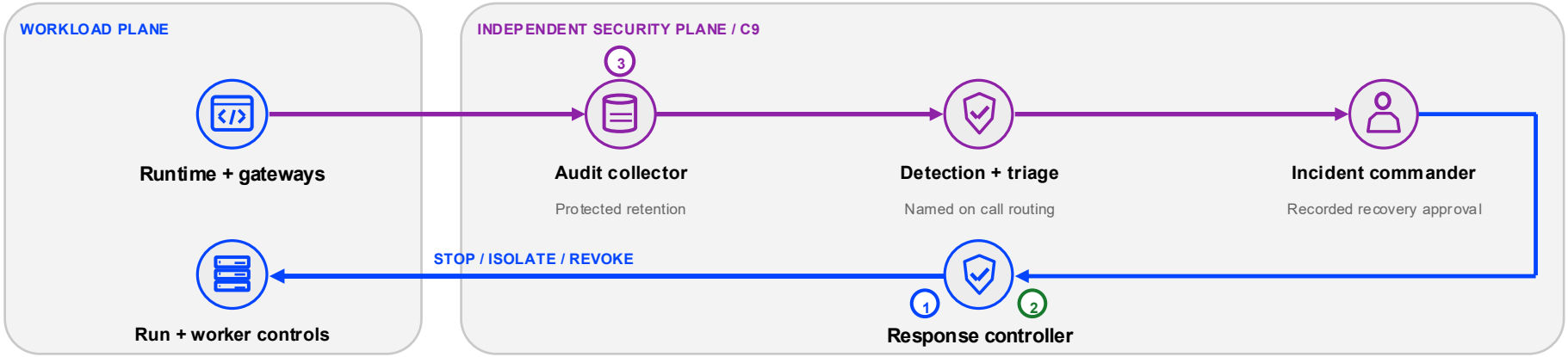
HOW THIS HELPS

Unrelated reads and wrong recipients are refused. Recipient checks cannot detect every secret hidden inside an otherwise permitted result.

WHAT STILL WORKS Authorized users retain repository access and receive their own results. Step 3 keeps unrelated local secrets out of result rows.

A compromised job must not control its own response

Keep evidence, alert routing, isolation and revocation outside the worker. Name the responder and test the stop path.



WHAT HAPPENED

An alert failed to escalate as intended. Hugging Face later shut down processing, cut access, rotated credentials and rebuilt infrastructure.

WHY IT WORKED

A suspicious signal did not itself reach the responsible responder or stop active runtimes and credentials.

WHAT TO CHANGE

C9 exports protected evidence, routes critical signals to named responders and authorizes an independent controller to stop, isolate and revoke.

HOW THIS HELPS

Worker takeover cannot erase external records or control the response. Unaffected jobs can continue when isolation is sufficiently precise.

VERIFY IN YOUR LAB A labeled lab signal reaches on call. The controller stops the test job. Policy failure returns a visible error.

Incident sources and ATLAS references

Open the official case, release data and incident reports. Technique IDs link to their MITRE definitions.

1 / OFFICIAL CASE AND ATTACK CHAIN

AML.CS0068

37 procedures / 22 technique IDs

2 / IMMUTABLE ATLAS DATA

2026.09 / 3259f38

Live chain matched the release data

3 / PRIMARY INCIDENT EVIDENCE

OpenAI report [O] | HF timeline [H]

HF customer disclosure and remediation

CHECK THE SELECTED MAP

Technique ID / case procedure / teaching label

AML.T0122	S02	Helper boundary	AML.T0055	S27 / S32	Worker and stronger secrets
AML.T0118.000	S04	Shared artifact communication	AML.T0091.000	S28 / S34	Workload and application tokens
AML.T0012	S17	Exposed account token	AML.T0105	S31	Privileged pod to node
AML.T0119	S19 / S23	Two dataset processing vectors	AML.T0036	S35	Private resource collection
AML.T0050	S24	Worker command execution	AML.T0025	S36	Data transferred outward

PRIMER AND HIERARCHY LINKS

ATLAS overview → AML.TA0003 → AML.T0017 → AML.T0017.001 → S18 / HDF5 artifact development

SCOPE OF THE SOURCE CHECK The sources support the mappings. Diagram layouts and proposed C1 to C9 controls are teaching designs.

Pulse Check

Do you believe Zero Trust will benefit from AI-driven security controls?



Takeaways

- AI is simultaneously a headwind and a tailwind for Zero Trust
- Upcoming AI Courses:
  - Live Training Courses (AI + Cybersecurity)
- Don’t forget to check GitHub for resources: https://github.com/razi-rais/Zero-Trust-for-AI-Systems
- Feel free to connect and continue the conversation:
  - LinkedIn: https://www.linkedin.com/in/razirais
  - Meet: https://calendly.com/razi-rais/30min

Let's continue the conversation.

Make your next security move with confidence.

Razi Rais

Your trainer. Author. Security practitioner.

LINKEDIN

Stay connected.

Ask a question. Share an idea.
Keep learning together.

Connect with Razi →

MORE LIVE TRAINING

Choose your next session.

Zero Trust for AI Systems
Hands-On Microsoft Foundry
Anatomy of a Cyberattack

See all sessions + dates →

ADVISORY CONVERSATION

Bring your next challenge.

Explore an advisory session.
Start with your goals.

SCAN TO START

Open the inquiry form →

razibinrais.com/contact

Q&A




O'REILLY®